Arabian Journal for Science and Engineering
https://doi.org/10.1007/s13369-026-11430-8

RESEARCH ARTICLE-COMPUTER ENGINEERING AND COMPUTER SCIENCE

Navigating Privacy in Digital Twin: A Framework for Regulatory Compliance (DTFRC)

Alaa Tolah[1] · Omar Alghamdi[1] · Noura M. Aleisa[1] · Niddal H. Imam[1] · Soha Alhelaly[1]

Received: 24 November 2025 / Accepted: 18 May 2026
© The Author(s) 2026

Abstract
Digital twin (DT) technology has gained significant adoption across domains such as healthcare, manufacturing, and smart cities due to its ability to mirror physical systems and provide real-time intelligence. However, the extensive collection, processing, and sharing of sensitive personal and operational data within DT systems raise substantial challenges related to privacy, security, and regulatory compliance. Although established frameworks—including the General Data Protection Regulation (GDPR), National Institute of Standards and Technology (NIST) guidelines, and International Organization for Standardization (ISO) standards—offer foundational protections, existing research lacks comprehensive compliance models tailored to the multi-layered architecture of DTs. This study examines the evolving regulatory landscape governing DT systems, identifies key compliance challenges, and highlights critical gaps in existing practices. This study conducts a systematic literature review of 31 primary studies, revealing that there are limited DT-specific regulatory frameworks, and only 2 out of 31 studies propose structured compliance frameworks. These findings highlight a significant gap in integrating regulatory requirements across DT functional layers. To address these gaps, we propose a novel Digital Twin Framework for Regulatory Compliance (DTFRC) that specifies and maps GDPR, NIST, and ISO requirements across five DT functional layers. The framework operationalizes legal and industry requirements across the DT technology stack, including IoT, data analytics, Explainable AI (XAI), immersive interfaces, and verification mechanisms. The framework also integrates a multi-level compliance governance structure, Security Education, Training, and Awareness (SETA) strategies to define measurable compliance metrics for continuous monitoring and improvement. The framework emphasizes embedding compliance considerations early in the DT life cycle to enhance transparency, resilience, and trustworthiness in real-world deployments.

Keywords Digital twin · Regulatory compliance · Privacy · GDPR · NIST · ISO · Governance · Framework

1 Introduction

In recent years, digital twins have been one of the emerging technologies offering simulation abilities to predict and interpret conditions and operations. Digital twins have gained significant traction across different sectors, ranging from healthcare to manufacturing to urban planning. Digital twin technology offers transformative opportunities for enhanced operational efficiency, predictive maintenance, and product lifecycle management [1]. These virtual replicas of physical entities or systems increasingly integrate with real-time data and artificial intelligence (AI)-driven insights, often involving sensitive personal, sensor data, or organizational information. As these systems expand, they pose significant privacy and regulatory compliance challenges [2].

Governments and regulatory bodies worldwide are developing and adapting frameworks to safeguard data privacy, security, and ethical considerations. Regulations such as the General Data Protection Regulation (GDPR), the National Institute of Standards and Technology (NIST) guidelines, and the International Organization for Stan-

✉ Alaa Tolah
a.tolah@seu.edu.sa

Omar Alghamdi
oalghamdi@seu.edu.sa

Noura M. Aleisa
n.aleisa@seu.edu.sa

Niddal H. Imam
n.imam@seu.edu.sa

Soha Alhelaly
s.alhelaly@seu.edu.sa

[1] College of Computing and Informatics, Saudi Electronic University, Riyadh 43017-6221, Saudi Arabia

Published online: 26 June 2026

dardization (ISO)/International Electrotechnical Commission (IEC) 27001 standard require comprehensive measures to protect sensitive data, including encryption, access controls, and consent mechanisms [2, 3]. However, the complexity and diverse applications of digital twins present significant challenges to achieving full compliance with these regulations.

1.1 Research Gaps

A review of regulatory frameworks such as General Data Protection Regulation (GDPR), California Consumer Privacy Act (CCPA), and Health Insurance Portability and Accountability Act (HIPAA) reveals that while these frameworks cover general data protection, they still lack specificity for emerging technologies like digital twin [3, 4]. Current literature investigates data protection measures such as anonymization, encryption, and consent management, but limited attention has been given to the intersection of privacy regulations and digital twin technology [1, 3]. Also, digital twin developers frequently encounter challenges in ensuring compliance with the regulatory landscape, which can result in inefficient systems, non-compliance risks, and missed opportunities for innovation [2–4]. Given the growing influence of digital twin in shaping the future of organizations, it is important to have strong privacy measures that comply with the evolving regulatory landscape and security standards [3, 4]. This integration requires a conceptual framework for addressing the regulatory and privacy challenges.

1.2 Contributions

Therefore, this research aims to fill this gap in digital twin by addressing regulatory compliance challenges while leveraging technological advancements to ensure secure and compliant implementations. By examining current frameworks and identifying gaps in compliance practices, a comprehensive analysis of existing studies was conducted to derive design considerations for privacy measures that are aligned with regulatory requirements in digital twin systems. In addition, it will assist regulators in adapting existing frameworks to address the complexities of digital twin technology. Ultimately, this research will contribute to a sustainable and secure environment for the continued development of digital twin technologies. To the best of the authors' knowledge, this paper is the first of its kind to propose a comprehensive DTs framework that integrates key guidelines issued by NIST, GDPR, and ISO. Thus, our contributions can be summarized as follows:

1. Exploring the state-of-the-art of DT regulatory compliance through conducting a systematic literature review.
2. Discussing standardization, compliance, and regulatory framework for DT and commenting on current challenges and opportunities.
3. Examining current regulatory compliance frameworks for DTs and identifying gaps in compliance practices.
4. Presenting and discussing regulatory compliance considerations for DTs' components across the functionality layers.
5. Mapping common regulatory standards to the corresponding privacy and security requirements relevant to Digital Twin applications.
6. Developing a DT Framework for Regulatory Compliance (DTFRC) to promote best practices in data management, cybersecurity, and governance.

The remainder of this paper is structured as follows. Section 2 reviews the existing literature on Digital Twin (DT) regulatory compliance and outlines the systematic literature review (SLR) methodology and findings. Section 3 describes the research methodology and introduces the proposed framework for DT regulatory compliance. Section 4 presents the conclusions derived from the study. Finally, directions for future research are discussed in Sect. 4.1.

2 Literature Review

A systematic literature review (SLR) was conducted to examine research findings on regulatory aspects of digital twin (DT) systems. The review followed the established guidelines proposed by [5, 6], which structure the SLR process into three main phases: planning, conducting, and reporting. These phases are illustrated in Fig. 1. The overall review process, formatting conventions, and selected figures were adapted from prior studies [5, 7], ensuring methodological rigor and consistency with best practices in evidence-based software engineering research.

2.1 Definition of Research Questions

The research questions (RQs) were explicitly formulated to maintain the focus and scope of the review. Table 1 presents the research questions alongside their corresponding objectives. The set of RQs was developed collaboratively through discussions among a team of five researchers, with the primary aim of ensuring comprehensive coverage of the domain. The central objective of this process was to identify and synthesize key research contributions that address regulatory compliance in digital twin (DT) systems.

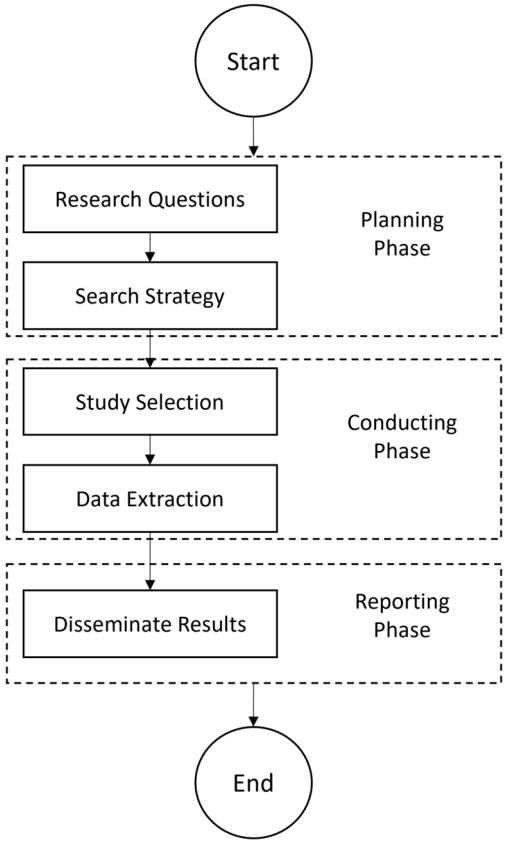


Fig. 1 SLR three phases [5, 6]

Table 1 Research questions

No	Research questions	Research objectives
RQ1	What are the key regulatory requirements and standards relevant to DTs across various sectors?	To identify the current privacy applied to the DT systems
RQ2	How does data privacy legislation (GDPR, CCPA) affect the design and implementation of data management within DT?	To analyze how compliance with these regulations affects the development and usage of DTs across various industries
RQ2	What are the gaps, challenges, and opportunities organizations face in achieving regulatory compliance in their DT?	To analyze how compliance with these regulations affects the development and usage of DTs across various industries and identify opportunities for improvement
RQ3	How can frameworks ensure compliance with relevant data privacy regulations in different sectors?	To identify and analyze existing frameworks for DTs regulatory compliance

Table 2 Digital libraries

Digital library	No. of papers
IEEE	18
Wiley online library	50
Web of science	7
Google scholar	961
Total	1036

2.2 Search Strategy

This phase consisted of several activities: selecting relevant digital libraries, defining and refining search terms, conducting a pilot search, and retrieving an initial set of primary studies from the selected databases [5]. For this study, searches were carried out in widely used digital libraries within the field, using a predefined search string. The search term applied was: ("Digital Twin" OR "Digital Twin") AND ("regulatory compliance"). Table 2 summarizes the results of the search across the selected digital libraries.

2.3 Study Selection

The selection of primary studies was guided by predefined inclusion and exclusion criteria, which were applied systematically across four screening levels. At each level, studies that did not meet the eligibility requirements were excluded. Table 3 outlines the detailed inclusion criteria (IC) and exclusion criteria (EC) used in the process.

The initial search query yielded 961 articles from major digital libraries, including MEDLINE, Web of Science, IEEE Xplore, and the ACM Digital Library. Following the application of IC 1 together with EC 1-3, the pool was reduced to 961 potentially relevant studies. Subsequent filtering using IC 2-4 narrowed the selection to 41 articles. These 41 studies were subjected to a full-text review, after which 10 articles were excluded due to a lack of access to the complete text. This process resulted in a final set of 31 primary studies selected for detailed analysis in accordance with the SLR approach. Figure 2 illustrates the study selection process in the form of a PRISMA-style flow diagram.

2.4 Data Extraction

In this stage, data were extracted from selected primary studies to collect the evidence necessary to address the research questions. Six properties, derived directly from the research questions, were identified as the basis for the analysis, as shown in Table 4. These properties enabled the classification of the selected articles and facilitated systematic responses to the research questions.

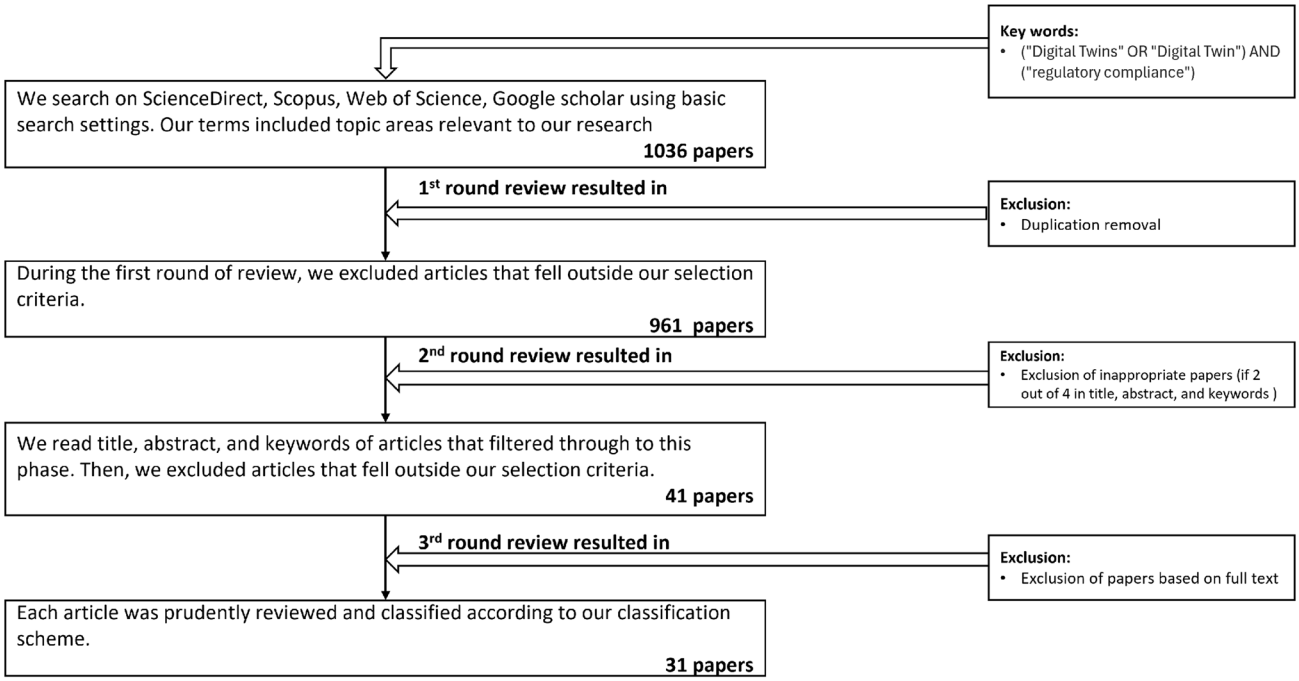


Fig. 2 SLR flow chart

Table 3 Inclusion and exclusion criteria [8, 9]

Criteria	Description
IC 1	The paper should address the Regulator Compliance within the Digital Twin
IC 2	A well-written article reported at least three out of the keywords
IC 3	Articles published in a peer-reviewed journal or a conference
IC 4	Articles published in the last ten years were included (i.e., 2014–2025)
EC 1	Similar articles from different digital libraries
EC 2	Thesis, news articles, reports, or websites were excluded
EC 3	Articles published in a language other than English were excluded

The initial results of this step revealed that only 32.26% of the selected studies explicitly discussed regulations and standards directly applicable to DTs. The majority of papers addressed opportunities and challenges associated with the adoption of DTs, while only three studies specifically examined the impact of regulatory compliance on the design, development, and deployment of DT systems. Overall, answers to the research questions were found in 10 of the 31 reviewed papers, as shown in Table 5. Notably, only two of the 31 studies proposed a dedicated regulatory framework for DTs, even though most of the reviewed literature acknowledged its importance.

Table 4 Research questions properties

Properties	Research questions
Aim of the study	RQ1
Countries examined	RQ1
Specific industry	RQ1
Methods used	RQ2, RQ3
Factors impacting RC	RQ2, RQ3
Type of users	RQ2, RQ3

2.5 Results and Discussion

This study was guided by three main research questions, which informed both the literature analysis and the initial design of the proposed compliance framework. The detailed findings corresponding to each research question are summarized in Table 1 and discussed in the following subsections.

2.5.1 DT Regulations and Standards (RQ1)

The objective of RQ1 was to identify the key regulatory requirements and standards relevant to DTs in different sectors. The analysis of the selected primary studies identified 13 regulatory instruments, of which only three were found to be directly applicable to DTs: the General Data Protection Regulation (GDPR), the National Institute of Standards and Technology (NIST) frameworks, and the International Organization for Standardization (ISO) standards. For exam-

ple, Esiri et al. [10] emphasize the importance of regulatory compliance in the adoption of DTs in the oil and gas industry. They highlight that both NIST and GDPR provide guidelines for the responsible and secure handling of data collected through IoT and processed by ML components within DT architectures. They also note that ISO standards are relevant to DTs as they provide guidelines for managing physical assets. Similarly, Czekster et al. [11] underscore the necessity of complying with national and international regulations governing data governance, privacy, and security. They reference multiple relevant instruments, including ISO definitions of DT concepts and terminology, IEEE 1451 standards for IoT integration in DT federations, and draft NIST standards outlining DT features, functions, and operational technologies. Armeni et al. [12] further add that compliance with privacy regulations such as GDPR in Europe, as well as other national data protection laws, is mandatory given that DTs routinely process personal data.

Beyond privacy and security, several studies also note the importance of adhering to industry-specific safety standards as DTs are increasingly adopted across sectors. For example, Armeni et al. [12] stress that compliance with safety regulations in the oil and gas industry, such as the Occupational Safety and Health Administration (OSHA) guidelines and International Maritime Organization (IMO) standards, can enhance operational safety and ensure safe working conditions. In the aviation sector, Fakhraian et al. [13] argue that identifying domain-specific safety regulations is a prerequisite to fully realizing the potential of DT applications. In healthcare, Eswaran et al. [14] reference the Health Insurance Portability and Accountability Act (HIPAA), while Vaghani et al. [15] highlight compliance with US Food and Drug Administration (FDA) requirements. Furthermore, Rahmadian et al. [16] classify relevant regulatory instruments into two broad categories: non-technological governance regulations (e.g., GDPR) and technological cyber-governance regulations (e.g., DT architectural frameworks).

In summary, the findings suggest that two categories of regulations and standards must be considered when adopting DTs. The first category encompasses data privacy and security regulations that directly apply to DTs, such as GDPR and NIST. The second category comprises sector-specific regulations and standards, including OSHA and IMO in oil and gas, HIPAA and FDA requirements in healthcare, and aviation safety standards. Together, these two categories highlight the dual importance of complying with general data governance frameworks and domain-specific regulatory requirements in DT deployments.

2.5.2 Challenges and Opportunities (RQ2)

The objective of RQ2 was to analyze how compliance with regulations influences the development and deployment of DTs across industries, and to identify opportunities for improvement. While compliance with data governance, privacy, and security frameworks is essential, it introduces several challenges that organizations must address.

Several studies highlight these challenges. Armeni et al. [12] emphasize that organizations must continuously monitor evolving regulations to mitigate legal and financial risks. Bakare et al. [17] note that the complexity and variability of regulatory requirements across jurisdictions pose significant obstacles, as companies must comply simultaneously with multiple frameworks, including both data privacy laws and industry-specific standards. Failure to meet these requirements may result in financial penalties and reputational damage. Vaghani et al. [15] similarly argue that global compliance is inherently complex, as DTs must adhere to both safety and reliability standards in addition to data protection obligations. Giel et al. [18] further classify regulatory compliance as an organizational challenge that can hinder the development of DTs for critical systems such as internal transport networks.

Beyond complexity, cybersecurity has emerged in the literature as a primary compliance-driven constraint influencing the development and deployment of digital twins (DT). Digital twins integrate real-time data flows, Internet of Things (IoT) connectivity, and cyber-physical systems, which can increase the attack surface and expose both virtual and physical assets to malicious actors. Surveys have identified a range of security threats, including unauthorized access, data tampering, and cascading impacts resulting from the close coupling between digital replicas and physical systems; many of these threats remain inadequately addressed in current implementations [2, 19]. Recent systematic analyses highlight the need for structured risk assessment and auditing approaches specifically designed for DT environments to ensure dependability, data integrity, and regulatory compliance across industries [20]. Although the literature discusses techniques to enhance DT security, including new paradigms and protective measures, comprehensive security analysis is often absent from discussion of regulatory compliance. This omission highlights a gap that future frameworks should address [21].

At the same time, regulatory compliance also presents opportunities for advancing DT practices. For example, Vaghani et al. [15] demonstrate that DTs can facilitate compliance in healthcare by creating digital audit trails of device performance during simulations. By replicating the operational environment of medical devices, DT models enable testing under near-real-world conditions, supporting early detection of issues and facilitating regulatory approval. Raitviir et al. [22] highlight the potential of integrating governmental and municipal DT platforms to enhance collaboration, improve regulatory compliance, and optimize construction practices. Rahmadian et al. [16] stress the

importance of involving legal experts and business analysts in DT development to address legal compliance challenges, given that implementing regulatory frameworks requires interdisciplinary expertise. Similarly, Giel et al. [18] suggest that the adoption of modern project management tools, the introduction of periodic compliance reviews, and the engagement of legal teams early in the DT development process can help organizations mitigate compliance challenges and leverage opportunities for improvement.

2.5.3 Regulations Compliance Framework (RQ3)

The objective of RQ3 was to identify existing frameworks for ensuring regulatory compliance in DT systems. The majority of the reviewed papers acknowledge the importance of developing such frameworks, driven by the increasing adoption of DTs and the corresponding rise in risks such as data security breaches and regulatory non-compliance. Consequently, a comprehensive framework that incorporates principles of big data governance is considered essential to maximize the benefits of DT technologies while mitigating potential risks [16]. Despite this recognized importance, the review revealed that only two of the 31 selected studies proposed a concrete regulatory compliance framework for DTs.

Czekster et al. [11] provide an example in the context of Federated Digital Twin (FDT) for transportation systems. Their framework adopts a multi-layered approach in which a dedicated layer for regulatory alignment checks is included to ensure compliance across distributed DTs. Adhering to regulations and standards was not the main focus of this study. It suggests adding a dedicated layer for regulatory alignment checks to ensure compliance across distributed DTs. It addressed national and international regulations, such as NIST and ISO, but it does not address GDPR, which is crucial for ensuring DTs' data privacy.

Additionally, Rahmadian et al. [16] propose a framework designed to ensure accountability, transparency, and trustworthiness in DT development while adhering to relevant regulations and standards. Their framework consists of three layers: (1) stakeholder identification, (2) identification of applicable laws and regulations, and (3) the use of documentation frameworks for architecture decisions (DFAD). The authors demonstrate their application in the domain of smart and sustainable tourism, including a DT architectural synthesis. Although it proposes a documentation framework, it was not designed specifically for digital twins. Instead, it aims to encourage the application of DFAD to support big data governance within the DT domain, addressing regulatory considerations such as GDPR and ISO standards. However, it does not discuss NIST guidelines, which are essential for achieving cybersecurity compliance in DT environments. While the GDPR primarily defines the legal and ethical obligations for handling personal data, NIST offers practical, technical, and organizational guidelines that operationalize these principles across DT environments. Specifically, NIST frameworks and publications address critical aspects such as system architecture, cybersecurity, risk management, and data governance, all of which are essential for ensuring that DT implementations adhere to GDPR requirements in practice. By aligning GDPR's legal principles with NIST's technical and organizational frameworks, organizations can establish a robust governance structure that not only ensures compliance but also fosters trust and resilience in the deployment of DT systems.

The broader literature consistently emphasizes the need for regulatory compliance frameworks that go beyond static alignment checks. We argue that a more integrated approach is required, whereby regulatory information actively informs and guides design decisions throughout the DT lifecycle. This shift necessitates moving beyond automated compliance checks toward advanced tools that support designers in making informed, regulation-aware decisions in real time. The results of this SLR highlight a significant gap: existing studies rarely provide frameworks that consider the compliance requirements of DT architecture's underlying technologies, focusing instead on DTs as a single integrated system.

To the best of the authors' knowledge, this study represents the first systematic attempt to design a DT regulatory compliance framework that integrates ISO standards, GDPR principles, and NIST controls to enable organizations to implement a holistic and internationally aligned approach to DT governance. Table 5 presents a comparative analysis of the ten selected articles. It summarizes their contributions to Digital Twin (DT) regulatory compliance as well as their limitations. Also, the table maps each paper to the corresponding research question addressed in the study. Additionally, Table 6 positions the proposed DTFRC framework relative to the literature and identifies existing gaps in regulatory integration and structured compliance design. The comparison matrix was developed based on the SLR results. The dimensions reflect regulatory depth, industry scope, DT-specific, empirical validation, and compliance mechanisms. The following section builds on these insights by examining the regulatory requirements associated with DT architecture components and technologies in greater detail.

2.6 Digital Twin Architecture

Several DT architectures have been proposed in the literature, generally structured in layers, with each layer encompassing distinct technologies and components. In most cases, DT architectures are organized into four functional layers, although variations exist across application domains. This section summarizes representative DT architectures discussed in previous studies. It also explores regulatory

Table 5 Summary of the literature

Title	Summary	Limitation	Research question
[13]	Examines the integration of Digital Twins (DTs) within a unified framework, aligning regulatory, technical, and operational dimensions	Primarily concentrates on sector-specific safety regulations, overlooking data privacy and cybersecurity requirements. It does not introduce a structured regulatory compliance framework	RQ1
[10]	Investigates regulatory and governance requirements for DT adoption in the oil and gas sector, outlining policy-level considerations and compliance challenges	Provides strategic insights into regulatory directions but lacks a formalized compliance framework or empirical validation through practical implementation	RQ1
[11]	Proposes a multi-layered interoperability architecture for Federated Digital Twins (FDTs), incorporating a regulatory alignment layer within distributed DT environments	Regulatory compliance is treated as a secondary component. While NIST and ISO are acknowledged, the absence of GDPR consideration limits comprehensive data protection coverage	RQ1
[16]	Introduces a Documentation Framework for Architectural Decisions (DFAD) to support regulatory traceability, demonstrated through a smart tourism DT case study	The framework is not explicitly tailored to DT environments and lacks integration of cybersecurity standards such as NIST, reducing its applicability for DT-specific compliance assurance	RQ1-3
[15]	Analyzes DT implementation challenges in the medical device industry, emphasizing regulatory constraints, data standardization, and cybersecurity risks	Focuses narrowly on FDA requirements without addressing broader data protection and cybersecurity regulations. No structured compliance architecture is proposed	RQ1-3
[18]	Explores organizational and regulatory challenges associated with developing high-fidelity DT systems in transportation contexts	Identifies compliance-related issues but does not advance a formal regulatory framework or systematic compliance mechanism	RQ1-2
[12]	Evaluates DT adoption in healthcare, highlighting regulatory barriers and governance considerations affecting implementation	Discusses GDPR implications at a high level but does not propose a structured or operationalized compliance framework	RQ1
[22]	Conceptualizes integration strategies for governmental and municipal DT platforms to enhance collaboration and regulatory alignment in construction	Addresses compliance opportunities conceptually but does not formalize regulatory mapping or compliance enforcement mechanisms	RQ2
[14]	Examines the convergence of DTs and predictive analytics in healthcare, emphasizing regulatory compliance considerations supported by case illustrations	While regulatory awareness is acknowledged, the study does not develop a dedicated compliance framework or DT-specific regulatory model	RQ1
[17]	Proposes a governance–risk integration model aimed at strengthening accountability and regulatory adherence in oil and gas DT ecosystems	Although governance structures are articulated, the model lacks DT-specific regulatory mapping and does not operationalize compliance mechanisms	RQ2-3

compliance across the functional layers of the DT architecture.

Alcaraz et al. [2] propose an architecture that abstracts four layers of functionality: data acquisition, data management, data modeling, and data visualization. The distinction between these layers lies in the level of data processing and the enabling technologies employed. Similarly, Minerva et al. [23] describe a four-layer architecture for an Industrial Internet of Things (IIoT) platform supporting DTs. Their model includes: (i) a *data layer* representing heterogeneous sources to be integrated; (ii) an *integration layer* responsible for combining and managing data flows; (iii) a *service layer* that provides capabilities such as component control and DT management; and (iv) a *business layer* addressing business logic and operational decision-making. The classical four-layer model has also been adopted and refined in other studies [9, 24].

Alternative reference models adopt different abstractions. Lu et al. [25] present a three-component model consisting of: a physical object that abstracts the specifications of a physical entity; a communication channel linking the DT with its physical counterpart for data transfer; and a data processing module that constructs a live representation of the entity. Bevilacqua et al. [26] propose a DT reference model for risk reduction in process plants, comprising four layers: a *physical space layer* containing industrial resources (products, personnel, equipment); a *communication layer* responsible for data transfer; a *digital twin layer* simulating the physical

Table 6 Comparison of Regulatory Compliance in Digital Twin Studies

Study	NIST	ISO	GDPR	Other Reg.	Industry Scope	Compliance Framework	DT-Specific	Empirical Validation	Compliance Mechanism
[13]	No	No	No	ER	Aviation	No	No	No	Conceptual integration discussion
[10]	Yes	Yes	Yes	-	Oil & Gas	No	No	No	Policy and governance discussion
[11]	Yes	Yes	No	ENISA	Transportation	Partial	No	No	Regulatory alignment layer (architectural)
[16]	No	Yes	Yes	ITE	Tourism	Yes	No	Case Study	Documentation-based compliance
[15]	No	No	No	FDA	Health	No	No	No	Risk and regulatory discussion
[18]	No	No	No	Unspecified	Transportation	No	No	No	Organizational compliance discussion
[12]	No	No	Yes	-	Healthcare	No	No	No	Conceptual regulatory discussion
[22]	No	No	No	Unspecified	Construction	No	No	No	Conceptual governance discussion
[14]	No	No	Yes	HIPAA	Healthcare	No	No	Case Studies	Regulatory awareness emphasis
[17]	No	No	No	Unspecified	Oil and Gas	Partial	No	No	Governance and risk integration
This Study	**Yes**	**Yes**	**Yes**	-	**Industry-agnostic**	**Yes**	**Yes**	**No (Conceptual;**	**Governance and Regulatory**
(DTFRC)	**Yes**	**Yes**	**Yes**	-	**Industry-agnostic**	**Yes**	**Yes**	**SLR-based)**	**Mapping Architecture**

space; and a *user layer* enabling management of the replica through AR/VR. Iliuţua et al. [27] further introduce a three-dimensional reference model that conceptualizes DT along three axes: abstraction level, service lifecycle, and integration dimension (ranging from Digital Model to Digital Shadow, Digital Twin, and Predictive Digital Twin).

For this study, we adopt a consolidated framework based on the architectures proposed by Minerva et al. [23], Alcaraz et al. [2], and Homaei et al. [24], with further refinements introduced by Imam [9]. Figure 3 illustrates this DT architecture, outlining the components, interactions, and enabling technologies required to construct a virtual replica of a physical system.

Since DT frameworks inherently incorporate multiple technologies across their layered architectures, regulatory compliance must be considered at the level of these specific components and technologies. The following section discusses the regulatory requirements and standards applicable to DT architectural technologies, situating them within the broader compliance framework developed in this study.

2.6.1 Layer 1: Data Collection and Acquisition

The first layer of the DT framework focuses on data acquisition through Internet of Things (IoT) systems and other systems. This layer includes physical devices such as sensors, cameras, robots, and actuators, which are essential for capturing and transmitting data to local controllers. Regulatory compliance at this stage is critical to ensuring system compatibility, data protection, and data integrity. Several studies emphasize that by incorporating relevant principles and standards into the design process, integrating compliance mechanisms, and adopting best practices, designers can effectively address the complexities of regulatory requirements [9].

A primary example of this is the General Data Protection Regulation (GDPR), which provides basic principles and requirements that directly affect the design and functional operation of Layer 1 components. Compliance is commonly achieved through the integration of cryptographic techniques, blockchain-based architectures, smart contracts, and the adoption of a "privacy by design" approach. For instance, Barati et al. [28, 29] introduce a model that links IoT devices to a blockchain-based verification system, enabling compliance assessments for user consent, data minimization, protection, and transfer. Their framework employs three types of smart contracts: (i) a *privacy contract*, which records user consent and governs data processing purposes; (ii) a *submission contract*, which logs IoT device activities and encryption status; and (iii) a *verification contract*, which audits data recorded in the first two contracts to identify compliance violations. The workflow begins with IoT devices registering privacy policies on the blockchain, followed by user consent captured through the privacy contract, submission of device activities, and automated verification of compliance. This approach enhances transparency, accountability, and traceability of data flows.

Digital twins include heterogeneous components such as IoT sensors, cloud infrastructure, AI analytics, and immersive interfaces-raising privacy threats. Many studies have discussed the use of advanced technological mechanisms to enhance data privacy and security in cloud computing environments, such as blockchain technology, which was widely used to protect sensitive data from tampering and to provide reliable data storage by ensuring confidentiality, integrity, and availability. Using blockchain technology enables secure data sharing and reduces reliance on centralized trust authorities [30]. Blockchain-based secured aggregation methods have been used for edge computing environments, allowing privacy-preserving data aggregation from multiple nodes while preventing unauthorized manipulation. These methods are relevant for Internet-of-Things applications, where large volumes of data are created at the network edge and sent to centralized analytics platforms [31]. Another study has also explored the use of Blockchain-based secure storage mechanisms to protect sensitive data in distributed environments. Medical data storage frameworks include the use of rugged encryption algorithms, such as Blowfish, which provide access control and manipulation-resistant data protection. These approaches enhance data integrity, traceability, and resilience against unauthorized access [32]. These advanced technological mechanisms focus on cryptographic security and storage integrity rather than regulatory compliance, such as GDPR, NIST standards, and ISO standards. This identified gap motivates the development of the proposed Digital Twin Framework for Regulatory Compliance (DTFRC).

Blockchain-based personal health record systems have also been proposed as GDPR-compliant solutions. One such system, the Electronic Health Wallet (EHW), employs smart contracts to enforce access control rules and provide real-time data management. Functions such as `AddPolicy` and `UpdatePolicy` allow users to manage permissions, ensuring data integrity and interoperability, while granting individuals control over their personal data [33]. Similarly, the ADvoCATE platform leverages blockchain and smart contracts to manage user consent in distributed environments. Through an intuitive interface, users can manage device preferences and consent, while data controllers are obligated to comply with these preferences in accordance with GDPR requirements [34].

Truong et al. [35] propose a high-level platform architecture that reinforces decentralization, transparency, and data provenance. The framework integrates components for consent management, authentication, and logging, supported by public-key cryptography to secure sensitive data. Data owners provide consent via programmable contracts, service

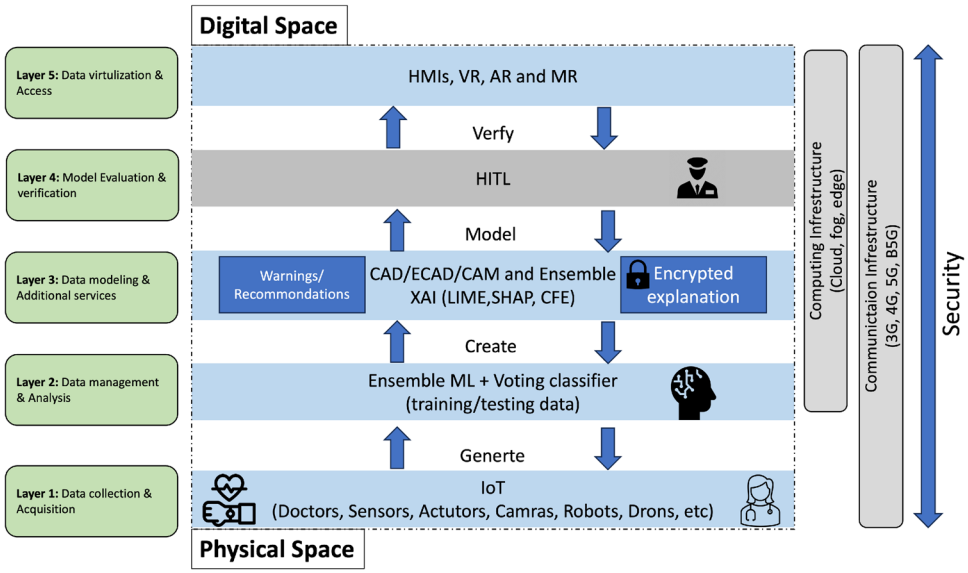


Fig. 3 Digital twin architecture [9]

providers request authorization, and data processors access the required information only once consent is verified. All data access and processing actions are immutably logged on a distributed ledger, ensuring accountability, traceability, and strong protection of user rights. Figure 4 illustrates a blockchain- and smart contract-based model designed to ensure compliance with GDPR principles, as proposed by Barati et al. [28, 29].

2.6.2 Layer 2: Data Management and Analysis

The second layer of the DT framework comprises data management and analysis, which serve as the backbone for effective implementation of the DT. This layer involves the collection, integration, storage, and analysis of data from physical systems to construct virtual representations that enable real-time insights, predictive capabilities, and informed decision-making, while also addressing privacy concerns [2, 9]. It supports descriptive, diagnostic, and predictive analytics, facilitating forecasting, pattern recognition, anomaly detection, performance optimization, and scenario analysis [2]. The effectiveness of DT systems relies heavily on this layer, as it ensures accurate data integration and the generation of actionable insights.

This layer leverages big data (BD), machine learning (ML), and artificial intelligence (AI) technologies to process both historical and real-time datasets. The integration of BD and AI/ML enhances scalability, improves system intelligence, and supports advanced decision-making [36]. BD technologies, such as distributed computing frameworks and cloud-based infrastructures, provide the infrastructure for large-scale data processing and real-time analytics [37]. These capabilities enable dynamic system adaptation and improved responsiveness. Meanwhile, AI techniques improve preprocessing, data integration, and anomaly detection, delivering structured, high-quality data. ML and Deep Learning (DL) algorithms further support data categorization and cleansing. In addition, AI-driven predictive analytics allow forecasting of system failures, proactive interventions, and performance optimization [36].

However, the extensive data collection and analysis within this layer introduce significant privacy and security concerns. Effective data governance policies—defining ownership, access rights, and usage rules—are required to safeguard confidentiality, integrity, and availability. Ensuring compliance with regulations such as GDPR and standards including ISO/IEC 27001 and the NIST Cybersecurity Framework is therefore essential [38]. To meet these requirements, organizations increasingly adopt advanced privacy-preserving methods such as federated learning, differential privacy, and blockchain. Several studies stress the necessity of integrating comprehensive governance frameworks into DTs to ensure alignment with GDPR and other regulatory mandates [38, 39].

Different approaches have been proposed to address compliance challenges in BD- and AI-enabled DTs. Rahmadian et al. [16] explore BD governance in DT applications for the tourism industry. They propose a Documentation Framework for Architectural Decisions (DFAD) that fosters accountability, transparency, and trustworthiness while ensuring adherence to privacy regulations. Their case study on Mobile Positioning Data (MPD) in Indonesia demonstrates how governance mechanisms support sustainable tourism through DT adoption. Similarly, Baumer et al. [40] introduce a framework for privacy risk identification in DTs derived from social media data. Their approach combines standardization, pseudonymization, and synthetic data generation using Large Language Models (LLMs), Generative Adver-

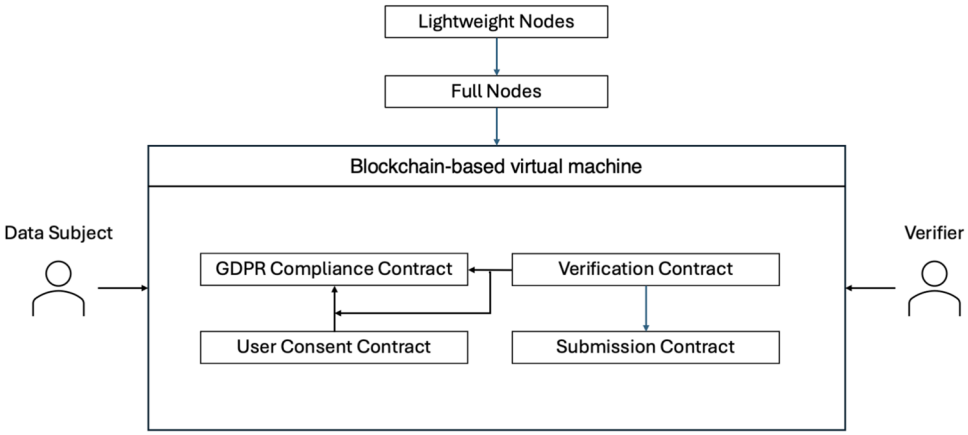


Fig. 4 Blockchain and smart contracts-based model [28, 29]

sarial Networks (GANs), and Vision Language Models. This method illustrates the feasibility of constructing privacy-preserving DTs while acknowledging the need for continuous refinement.

Other studies propose adaptive and domain-specific compliance frameworks. Zhang et al. [41] present a twin-oriented digital architecture integrating abstract goal modeling with fine-grained agent-based simulation for adaptive compliance in complex Cyber-Physical Systems (CPS). Their case study on smart warehouse logistics demonstrates how runtime prediction and trade-off analysis can balance conflicting goals such as safety and productivity. Garske et al. [42] analyze the role of DTs in supporting the EU Green Deal, emphasizing the need for a robust legal framework to ensure high-quality, accessible data for sustainability-oriented DT applications. Molin et al. [43] further stress the necessity of standardized data models and policies to promote interoperability and maintain compliance.

For the protection of sensitive data in cloud-based environments, a recent study has also proposed advanced encryption and anonymization techniques. A cloud-enabled healthcare framework includes SpectraSafe encryption with dynamic k-anonymity to safeguard confidentiality, which reduces the threat of unauthorized access and re-identification of sensitive data while allowing secure data processing [44]. Another study has also explored privacy-preserving collaborative computation techniques for distributed environments. Secure multi-party computation (MPC) frameworks allow different entities to process data together while safeguarding each input. Cloud-enabled MPC models use encryption and dynamic anonymization approaches, such as ℓ-diversity, to protect the data sharing and analysis of sensitive information, which reduces the data leakage in multi-stakeholder scenarios [45]. DT systems include various technologies that operate across DT architectural layers, which require governance frameworks to ensure alignment with legal and regulatory requirements such as GDPR, NIST, and ISO standards.

In summary, the data management and analysis layer underpins the core functionality of DTs by enabling predictive and intelligent operations through BD, ML, and AI. At the same time, it introduces significant regulatory challenges, particularly in relation to data governance and privacy. The literature highlights the critical need for integrated compliance frameworks, standardized data models, and advanced privacy-preserving techniques to ensure that DTs remain secure, trustworthy, and aligned with GDPR, NIST, and ISO standards. Consequently, this current study focuses on developing a comprehensive compliance framework tailored to the regulatory demands of DTs' layers.

2.6.3 Layer 3: Data Modeling and Additional Services

The third layer of the DT architecture focuses on data modeling and additional services, functioning as an intermediary that bridges the physical and virtual spaces. This layer employs various modeling tools, such as CAD/ECAD (electronic computer-aided design) systems and CAM (computer-aided manufacturing), to characterize the states, behaviors, and shapes of physical objects. Advanced frameworks further incorporate 3D modeling processes based on CAX (CAD/CAE/CAM) technologies, which use computer simulations to replicate physical environments. These capabilities enable the DT framework to reproduce the geometrical, physical, and behavioral characteristics of physical systems and to provide real-time responses to external stimuli [46, 47].

Explainable Artificial Intelligence (XAI) is an additional service that plays a critical role in this layer. Beyond modeling data, XAI provides the reasoning behind algorithmic decisions through explanation mechanisms at both global and local levels [9]. Explanations are particularly important when the outputs are unexpected, unfamiliar, or contested by users, as they enhance transparency, trust, and accountability [48]. Understanding the explainability of AI and ML algorithms from decision-making and system maintenance perspectives is thus essential for regulatory compliance within DTs [49].

The rise of XAI research coincides with an evolving regulatory landscape for AI at both national and international levels. The EU General Data Protection Regulation (GDPR) grants individuals a "right to explanation" for decisions made by automated systems. Similar provisions are included in the French Digital Republic Act, and the U.S. Fair Credit Reporting Act (FCRA) [50]. The Singapore AI Governance Framework also outlines XAI guidelines, while the proposed EU Artificial Intelligence Act briefly requires that AI systems be "sufficiently transparent" [51]. In addition, the European Parliament's AI Framework report highlights in Article 8 the role of explainability in reviewing technical processes [52]. These regulatory initiatives have garnered support from stakeholders such as the European Consumer Organization and Meta (Facebook) [50].

XAI also serves as a mechanism for regulatory compliance. By providing explanations, XAI allows experts and regulators to review system predictions and verify adherence to legal requirements [53]. Moreover, XAI enhances robustness and fairness in DTs, which are crucial for demonstrating compliance with data protection regulations such as the GDPR [54]. The U.S. National Institute of Standards and Technology (NIST) emphasizes XAI as a requirement for trustworthy AI, outlining four guiding principles for its implementation [55]. Sovrano et al. [51] propose a methodology for selecting suitable XAI methods to comply with GDPR, AI Act, and MDR requirements in smart medical devices. Their framework categorizes devices by control mechanisms (open-loop, closed-loop, and semi-closed-loop) and aligns them with relevant explainability mandates. Similarly, Grieman et al. [52] propose a risk-based AI regulatory framework that integrates XAI to avoid over-regulation and balance potential harms with system deployment.

Despite its promise, several limitations and challenges in regulating XAI have been identified. Current legal frameworks, including the GDPR and the AI Act, only partially address XAI requirements [52]. Persistent trade-offs between explainability and accuracy, as well as tensions between XAI and privacy, remain unresolved [56]. Furthermore, EU law does not distinguish between varying levels of explainability or the technical granularity of explanations. One of the most significant challenges lies in regulating diverse AI applications, each with unique complexities and risks [50]. As a result, XAI frameworks must remain adaptable, evolving in tandem with advances in AI technologies and the broader regulatory landscape [56].

In summary, Layer 3 highlights the importance of XAI in bridging data modeling, decision-making, and regulatory compliance. While XAI enhances transparency, fairness, and accountability, regulatory frameworks are still evolving and must adapt to balance explainability with accuracy and innovation. This underscores the necessity for flexible, risk-based, and domain-specific XAI governance models to ensure compliance and trust in DT systems.

2.6.4 Layer 4: Evaluation and Verification

The fourth layer of the DT framework is dedicated to evaluation and verification, which constitute critical yet challenging processes in the development of complex systems. These steps are essential for assessing the maturity of engineering approaches and ensuring the long-term sustainability of DTs' interactions with real-world systems. Evaluation and verification activities validate the alignment between conceptual vision and implemented solutions while measuring operational quality against system-defined metrics [57].

A growing body of research explores how regulatory compliance can be automated and embedded into evaluation processes. Chhetri et al. [58] introduce a data-protection-by-design tool aimed at automating GDPR compliance verification. Their approach translates GDPR legislation into code through semantic modeling of informed consent, incorporating industrial requirements such as interoperability and scalability. The system employs a legal knowledge graph (KG) to enable automated compliance checks and manage broken consent chains, thus facilitating real-time compliance verification. In a related study, the authors of [59] propose a privacy-by-design framework using the STS-ml extension of the Socio-Technical Security (STS) method [60], enabling the specification and verification of privacy policy rules. Similarly, Rhahla et al. [61] outline guidelines for GDPR compliance verification tailored to big data systems, addressing the challenges of managing large-scale unstructured data [62].

Machine learning (ML) techniques have also been employed to automate compliance verification. Amaral et al. [63] propose a strategy for verifying GDPR compliance in Data Processing Agreements (DPAs). Their conceptual model identifies compliance-relevant information types and applies predictive algorithms to detect potential breaches. Distributed ledger technologies (DLTs), including blockchain and smart contracts, have been adopted for monitoring, auditing, and verifying data operations. Barati et al. [64] demonstrate an immutable recording mechanism for transparent logging and auditing of personal data activities in cloud computing systems. Their experiments in a healthcare pharmacy scenario illustrate the potential of blockchain to enhance accountability and ensure GDPR compliance.

Evaluation and verification have also been studied in the context of ISO standards. Andres et al. [65] develop an expert system for assessing compliance with ISO 9001:2015 Quality Management System (QMS) requirements. Using a design science methodology, the framework converts ISO 9001 processes into a structured knowledge base,

enabling organizations to evaluate compliance and implement improvement measures. The process involves seven steps, including the verification of requirement accuracy, development of compliance checklists [66], and creation of a comprehensive rule set for the expert system.

In the automotive domain, Bahig et al. [67] propose a semi-formal verification framework aligned with ISO 26262 safety standards for Automotive Safety Integrity Levels (ASILs) C and D. Their approach converts UML finite-state machines into formal notations, applies model checking, and automatically detects violations of safety requirements. This method demonstrates that semi-formal verification can identify design issues earlier in the development lifecycle, thereby improving compliance with critical safety standards.

In summary, Layer 4 underscores the importance of embedding evaluation and verification mechanisms that not only validate DT functionality but also ensure compliance with GDPR, ISO, and domain-specific standards. Emerging approaches—including semantic modeling, ML-based compliance checks, and blockchain—enabled audit trails-highlight the growing role of automation in strengthening accountability and regulatory alignment. These methods collectively advance the sustainability, safety, and trustworthiness of DT systems.

2.6.5 Layer 5: Data Virtualization

The fifth layer of the DT framework focuses on visualization, enabling stakeholders to interact with digital models for improved decision-making regarding physical systems. This layer incorporates Human Machine Interfaces (HMIs), Virtual Reality (VR), Augmented Reality (AR), and Mixed Reality (MR), often collectively referred to as Extended Reality (XR). More recently, the term Immersive Extended Reality (IXR) has been used to emphasize immersive VR and MR experiences [68, 69]. These technologies are critical for enhancing understanding of physical entities, but because they involve human interaction and personal data collection, compliance with privacy and security regulations is essential.

VR applications, such as immersive headsets, frequently capture sensitive user data, including movement patterns, gestures, and physiological responses. However, specific regulatory frameworks for VR remain underdeveloped [70]. Although users expect highly personalized and engaging experiences, the data collection required to deliver these experiences raises significant privacy concerns [71]. In practice, general data protection laws such as the EU-GDPR are applied to VR contexts. GDPR mandates informed consent, data minimization, and privacy by design, providing a robust but non-specialized framework for addressing VR's data risks [71]. Nonetheless, scholars argue that GDPR struggles to keep pace with the rapid technological evolution of VR, leaving gaps in regulatory protection [72].

AR is expected to play a major role in future DT implementations. By design, AR technologies collect multimodal personal data, including images, videos, geolocation, audio, and movement data [73, 74]. These practices raise acute privacy concerns, necessitating compliance with data protection laws such as GDPR and the California Consumer Privacy Act (CCPA). Both emphasize user consent and privacy by design as regulatory cornerstones [74]. King et al. [74] note that the European Union strictly regulates the commercial use of personal information, whereas the USA lacks a comprehensive federal framework, relying instead on tort law in private spaces and more permissive rules in public spaces [75]. This divergence highlights significant regulatory fragmentation, which complicates global AR deployments.

Emerging regulations also extend to domain-specific contexts. For example, Bini et al. [68] analyze the applicability of the EU Medical Device Regulation (MDR 2017/745) to XR-enabled medical devices, concluding that the MDR requires further adaptation to adequately address XR applications. Across both VR and AR, GDPR is the most commonly referenced regulation; however, as studies note, its provisions are not tailored to XR-specific challenges. The absence of specialized frameworks leaves organizations reliant on general data protection laws, which may not fully mitigate risks associated with immersive technologies.

Despite the importance of XR in DT visualization, no regulation explicitly addresses the unique risks posed by HMIs, VR, AR, and MR. Existing frameworks, such as GDPR and CCPA, provide partial coverage but remain insufficient to accommodate the rapid evolution of immersive technologies. Issues such as continuous motion tracking, biometric profiling, and the blending of virtual and physical environments present challenges that extend beyond traditional privacy considerations.

In summary, the analysis of Layer 5 demonstrates that regulatory compliance in DT visualization is both critical and underdeveloped. While GDPR and related frameworks provide a foundation, they do not yet fully capture the complexities of XR-based interactions. Ensuring compliance requires organizations to integrate data protection principles proactively and to adopt privacy-by-design practices tailored to XR environments. Moreover, expert oversight, as emphasized in Layer 4, is essential even where automated compliance checks are deployed. Future regulatory frameworks must evolve to address XR-specific risks, ensuring that immersive technologies contribute to the trustworthiness and adoption of DT systems.

3 Research Methodology

To address the research questions, this study proposes the Digital Twin Framework for Regulatory Compliance

(DTFRC) as a conceptual architecture for embedding regulatory requirements within DT systems. The framework conceptualizes regulatory compliance as a multi-layer governance and architectural structure that integrates privacy, cybersecurity, and regulatory principles directly into the Digital Twin technology stack. The proposed framework design is informed by the findings of the systematic literature review and synthesizes regulatory principles derived from GDPR, NIST cybersecurity frameworks, and relevant ISO standards. Figure 5 illustrates the conceptual architecture of the proposed framework and the analytical components through which regulatory compliance is embedded within DT environments.

3.1 Regulatory Foundation of the Framework

The first analytical component of the DTFRC framework establishes the regulatory foundations governing DT environments. Digital twin systems operate across complex technological ecosystems that combine IoT infrastructures, cloud platforms, artificial intelligence analytics, and immersive interfaces [76]. These technologies process large volumes of sensitive personal and operational data, making regulatory compliance a critical design consideration. To construct a comprehensive regulatory foundation, the framework integrates principles derived from three major regulatory and standards ecosystems: GDPR principles, NIST cybersecurity frameworks, and ISO/IEC information security standards. Within the proposed framework, these regulatory instruments function as normative constraints that guide the architectural design and governance of DT systems, ensuring that compliance considerations are embedded throughout the system lifecycle rather than applied as external validation mechanisms.

Prior research has largely focused on industry-specific safety regulations and the necessity of compliance, such as OSHA standards for the oil and gas sector and HIPAA for healthcare, both aimed at mitigating risks and enhancing operational safety. Regulations can be broadly classified into two categories: (1) those centered on data security, protection, and privacy (e.g., GDPR and NIST), and (2) domain-specific regulations tailored to particular industries. The analysis identified 13 relevant research papers, of which three are directly applicable to DT technology. This study focuses primarily on the first category, addressing security and data privacy concerns.

3.1.1 Regulatory and Standards Foundations

Regulatory frameworks and international standards provide the foundation for ensuring privacy, security, and accountability in complex digital systems. For DT environments that involve continuous data collected and processed, adherence to established legal regulations and cybersecurity standards are important to achieve compliance and system trustworthiness. The most widely adopted frameworks and standards guiding these efforts are: GDPR, NIST and ISO.

General Data Protection Regulation (GDPR) provides comprehensive rules for the collection, storage, and processing of personal data, ensuring that individual privacy is safeguarded. To ensure compliance, the regulation articulates six foundational principles. Each specifying the conditions under which personal data must be lawfully collected and processed. In the proposed framework, GDPR considers the legal foundation pillar for personal data protection in DT systems. Particularly Articles 5, 25, and 32-which setup the necessity for data integrity, confidentiality, and security of processing, that impact the design of compliance-oriented DT architectures. Key articles include Article 5(1)(f) (integrity and confidentiality), Article 32 (security of processing), Article 33 (notification of personal data breaches to supervisory authorities), and Article 34 (communication of breaches to data subjects). Additional provisions regulate data handling practices, including Article 5 (principles relating to processing), Article 6 (lawfulness of processing), Article 7 (conditions for consent), Articles 12–14 (transparent information and access), Articles 15–20 (data subject rights), and Article 25 (data protection by design and by default). Collectively, these articles explain regulatory expectations for safeguarding personal data and give a standard for assessing DT compliance such as, unauthorized access, loss, alteration, or misuse of personal data. For DT systems, which often involve real-time collection and processing of sensitive personal or organizational data, adherence to these provisions ensures both legal compliance and trustworthiness of the system.

The National Institute of Standards and Technology (NIST) frameworks and standards provide a structured approach to managing data privacy risks and achieving cybersecurity compliance in DT environments. NIST provides a set of complementary standards and frameworks that play a pivotal role in advancing DT systems. NIST seeks to promote innovation, foster interoperability, and mitigate security and privacy risks, thereby contributing to the development of a trustworthy DT ecosystem [38]. The most relevant NIST standards and controls that support the secure collection, storage, and processing of data in DT systems include the following:

1. **Privacy Framework (PF):** A structured tool for managing privacy risks to individuals and organizations arising from the processing of sensitive personal and operational data in DTs [77]. It assists in identifying the categories of personal data processed within DT environments, while emphasizing the protection of individuals' rights and expectations.

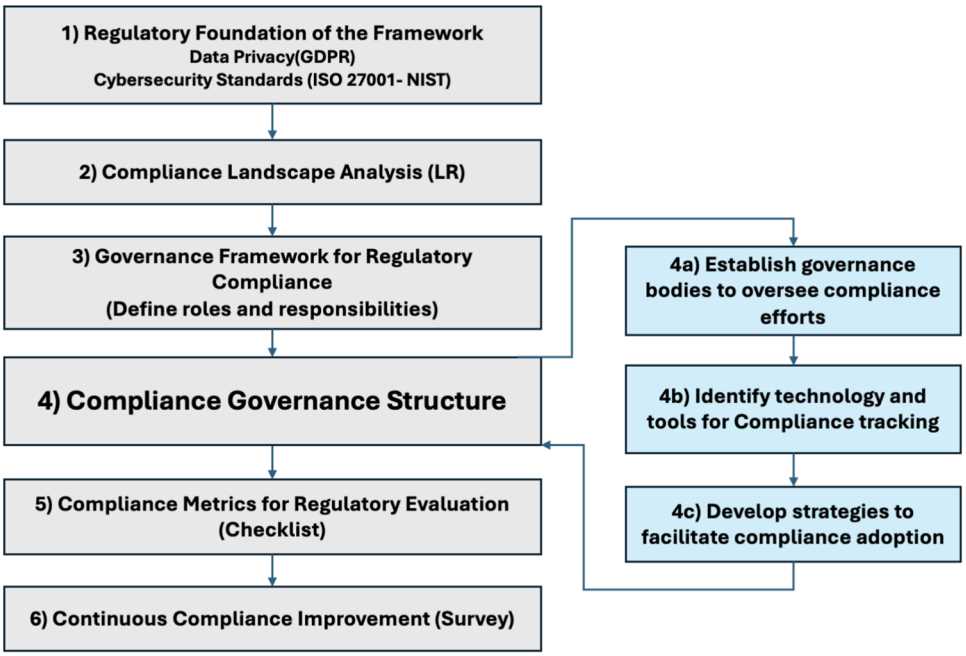


Fig. 5 Proposed Digital Twin Framework for Regulatory Compliance (DTFRC): conceptual architecture for integrating regulatory compliance into digital twin (DT) systems

2. **Interagency/Internal Report (IR) 8356-Security and Trust Considerations:** A recent guidance document that addresses DT-specific security and trust issues such as secure data exchange between physical and digital entities, real-time monitoring and integrity verification] [78, 79]. It delineates essential components and functions of the system, identifies cybersecurity challenges and provides recommendations aligned with existing NIST publications.
3. **Cybersecurity Framework (CSF):** A widely recognized reference model for managing and mitigating cybersecurity risks [39]. Organized around five core functions—Identify, Protect, Detect, Respond, and Recover. It offers actionable measures to protect interconnected IoT devices, data flows, and network infrastructures integral to DT operations. CSF helps organizations map all legal, regulatory, and contractual requirements and align cybersecurity risk management with organizational objectives [80].
4. **Risk Management Framework (RMF):** A comprehensive process for integrating security and privacy considerations into the system development life cycle [79]. The RMF facilitates an understanding of business processes, the purposes of the DT system, and the regulatory context, including legal and ethical constraints [81]. Its risk-based approach aligns with GDPR's accountability principle, enabling organizations to systematically address vulnerabilities within DT deployments.
5. **Special Publication (SP) 800 Series:** An extensive set of technical reports that provide detailed security and privacy controls [38]. These documents offer concrete methods for enhancing confidentiality, integrity, and availability, thereby reinforcing the GDPR's requirements for lawful, secure, and proportionate data processing.

These NIST frameworks provide actionable controls for cybersecurity governance, risk assessment, and continuous monitoring, making them essential for ensuring that DT systems meet both regulatory and operational security requirements.

International Organization for Standardization (ISO/IEC) standards are widely recognized across industries and jurisdictions, thereby offering a globally harmonized framework that facilitates interoperability, fosters trust, and supports regulatory compliance. ISO standards function as globally accepted benchmarks for best practices, ensuring consistency in the design, deployment, and governance of DT systems [82]. ISO standards relevant to DT technology offer guidelines for establishing information security and privacy management systems. The most significant ISO standards applicable to DT systems include:

1. **ISO/IEC 27001:2022—Information Security Management Systems (ISMS):** Establishes requirements for implementing, maintaining, and continuously improving an information security management system [82] . It includes risk assessment, access control, incident response, and continuous improvement, which are critical for safeguarding DT data assets. Its risk-based approach supports the confidentiality, integrity, and availability of data in DT infrastructures, complementing GDPR's security principle and NIST's CSF.

2. **ISO/IEC 27701:2019—Privacy Information Management Systems (PIMS):** Extends ISO/IEC 27001 by incorporating specific requirements for managing personally identifiable information (PII) [82] . It focuses on the collection, storage, and sharing of personal information while ensuring compliance with international privacy regulations. It directly supports GDPR compliance by operationalizing principles such as lawfulness, fairness, and purpose limitation within DT contexts.
3. **ISO/IEC 27005—Information Security Risk Management:** Provides guidelines for establishing a structured risk management process for information security [83]. This standard complements NIST's RMF by offering detailed methodologies for identifying, analyzing, and mitigating risks in DT environments.
4. **ISO/IEC 29100:2011—Privacy Framework:** Defines a high-level privacy framework outlining fundamental privacy principles such as consent, purpose specification, and accountability, which guide organizations in implementing privacy by design practices [84]. It reinforces GDPR's foundational principles while aligning with NIST's Privacy Framework, thereby offering a consistent reference for DT privacy management across international contexts.
5. **ISO/IEC 27018—Protection of PII in Public Clouds:** Specifies guidelines for protecting personally identifiable information in cloud environments [85] . Given that DT systems often rely on cloud-based infrastructures for data storage and processing, this standard provides essential controls to ensure lawful and transparent data handling.

In the context of DT systems, these ISO/IEC standards provide a structured approach for integrating security, privacy, and governance measures, complementing GDPR and NIST requirements and supporting a holistic regulatory compliance strategy [82, 86].

3.2 Compliance Landscape Analysis

The regulatory compliance landscape is examined through an analytical evaluation of risks, organizational practices, and the alignment of regulatory requirements across DT architectural layers. The analysis is informed by a comprehensive Systematic Literature Review (SLR) focusing on DT-related security regulations and standards, including GDPR, ISO/IEC standards, and NIST guidelines. The review analyzes existing privacy-preserving techniques and categorizes them into automated and semi-automated approaches across different DT architectural layers. The analysis concludes with a gap assessment comparing existing DT practices with applicable security and privacy requirements derived from regulatory frameworks. For instance, the review examines how contemporary DT applications address GDPR provisions related to data protection, user consent, and access control mechanisms. The findings revealed significant shortcomings, most notably the limited adoption of privacy-preserving techniques. The SLR therefore highlights structural gaps in current DT implementations and underscores the need for improved integration of established security standards.

Building on this, frameworks such as the NIST-CSF can be applied to evaluate the protective and detective capabilities of DT implementations against relevant standards and regulations (e.g., ISO/IEC 27001, NIST SP 800-53, GDPR). These assessments typically consider components within DT ecosystems as critical points of vulnerability such as sensors, simulation models, communication protocols, and cloud infrastructure components [80]. Similarly, the NIST-RMF can be leveraged to categorize DT systems, evaluate existing controls, and measure compliance with security requirements [81]. Moreover, NIST SP 800-53 provides structured processes to verify that implemented safeguards are both effective and operational [87]. A complementary approach is the use of ISO/IEC 27002:2022, which outlines detailed practices for implementing security controls aligned with the updated Annex A of ISO/IEC 27001, and ISO/IEC 27005:2022, which offers systematic methodologies for assessing and managing information security risks [83, 88]. Together, these standards and frameworks provide a rigorous foundation for conducting gap analyses and ensuring DT compliance with contemporary security and privacy regulations.

3.3 Governance Framework for Regulatory Compliance

The framework conceptualizes governance as a structured set of clearly defined policies and procedures to ensure regulatory alignment across DT operations that assign accountability for specific compliance tasks. Establishing such a framework requires clearly defined governance mechanisms that embed regulatory requirements within the operational architecture of DT systems.

These mechanisms conceptually address core domains such as data handling, incident response, and reporting mechanisms. In this section, a comprehensive compliance framework is presented, which systematically aligns DT privacy requirements with relevant regulatory and industry standards. Specifically, the framework maps GDPR principles, NIST standards, and ISO controls to the privacy and security obligations of DT implementations, providing a structured approach to ensure regulatory adherence and operational accountability.

3.3.1 Digital Twin Layer—Regulation Mapping

Digital twin technology is inherently data driven, relying on extensive acquisition, storage, and processing of data. Such practices necessitate strict adherence to data protection frameworks, the most notably GDPR. Within DT systems, the Internet of Things (IoT) facilitates data collection, machine learning (ML) enables data processing, and virtual reality (VR) supports data representation. As the volume of data increases, the accuracy and reliability of system outputs also improve. However, this dependence on personal and sensitive data heightens the risk of regulatory violations. Non-compliance with data protection requirements can result in severe penalties for data controllers and processors, in some cases culminating in organizational bankruptcy. The severity of sanctions is determined by the specific articles of the regulation that have been violated [89, 90]. GDPR articulates six core principles governing personal data processing, including lawfulness, accuracy, fairness, purpose limitation, data minimization, storage limitation, integrity, and confidentiality.

These six principles form the cornerstone of GDPR compliance and serve as a regulatory benchmark for the design and deployment of DT systems. Building on this foundation, Table 7 illustrates the mapping of GDPR principles to privacy requirements specific to DTs. For analytical clarity, data protection regulations were first categorized into four overarching groups. Each group was then systematically aligned with the relevant GDPR articles, thereby highlighting the regulatory basis for addressing privacy concerns in DT environments. In addition, the table provides an overview of representative privacy-preserving techniques presented in the literature that can be employed within each group to ensure compliance while sustaining the functional integrity of DT systems.

In addition to the regulatory foundations established by the GDPR, NIST offers practical, technical, and organizational guidelines that operationalize these principles across DT environments. Specifically, NIST frameworks and publications address critical aspects such as system architecture, cybersecurity, risk management, and data governance, all of which are essential for ensuring that DT implementations comply with GDPR requirements in practice. The most relevant NIST standards that support the security in DT systems include PF, CSF, RMF, SP800 Series, and IR 8356.

By aligning GDPR's legal principles with NIST's technical and organizational frameworks, organizations can establish a robust governance structure that not only ensures compliance but also fosters trust and resilience in the deployment of DT systems. Table 8 synthesizes this relationship by mapping NIST standards to the corresponding privacy requirements relevant to DT applications.

Alongside GDPR and NIST frameworks, ISO standards are particularly relevant to DTs as they address key areas such as information security management, privacy information management, and risk management. These standards provide actionable requirements and guidelines that can be directly mapped to both GDPR principles and NIST controls, thereby enabling organizations to implement a holistic and internationally aligned approach to DT governance. The most relevant ISO standards applicable to DT system include ISO/IEC 270010ISMS, ISO/IEC 27701-PIMS, ISO/IEC 27005—Information Risk Management, ISO/IEC 29100—Privacy Framework and ISO/IEC 27018—Protection of PII.

By integrating ISO standards with GDPR principles and NIST frameworks, organizations can achieve a multi-layered governance model that is legally compliant, technically robust, and internationally harmonized. This integration is particularly crucial for DTs, which inherently operate across domains, sectors, and jurisdictions. Table 9 provides the mapping of ISO's controls to privacy requirements related to DT.

Taken together, the GDPR, NIST, and ISO frameworks provide complementary layers of governance that are highly relevant to the development and deployment of DT systems. While the GDPR establishes the legal and ethical foundation by articulating the rights of individuals and the obligations of data controllers, NIST frameworks translate these obligations into actionable technical and organizational practices, particularly in the domains of cybersecurity, risk management, and trustworthiness. ISO standards, in turn, offer globally recognized benchmarks that harmonize these practices across industries and jurisdictions, ensuring consistency in the implementation of security and privacy controls. The integration of these three perspectives—legal (GDPR), technical and operational (NIST), and international best practice (ISO)—enables organizations to adopt a holistic approach to DT governance. Such alignment not only enhances compliance with regulatory requirements but also strengthens interoperability, mitigates systemic risks, and promotes the sustainable adoption of DT technologies across diverse sectors.

Since there is a remain gap in systematically mapping compliance regulatory requirements to the functional layers of DT architecture, this study bridges this gap by introducing a consolidated mapping of regulatory requirements framework designed to operationalize compliance across the DT life cycle. Table 10 presents the consolidated mapping of regulatory requirements and standards across five functional layers of DT architecture by aligning core technologies on each layer with the cybersecurity obligations, standards, and controls (GDPR, NIST, and ISO). Additionally, the table provides the alignment of compliance architecture across DT layers that presents how privacy, security, and governance requirements could be embedded across DT life cycle from data collection to visualization in order to ensure accountabil-

Table 7 Mapping of GDPR principles to DT's privacy requirements

Category	GDPR article #	GDPR article description	Privacy-preserving techniques	Reference
Data collection and integration	5	Data security measures, integrity and confidentiality	Access control mechanisms, Role-Based Access Control (RBAC), multi-factor authentication (MFA), blockchain-based access control	[40, 91, 92]
	5	Limiting personal data collection	Anonymization, pseudonymization	[89, 93]
	7	Valid consent has to comply with the ICO six rules	Valid consent has to comply with the ICO six rules	[94]
	9	sensitive data explicit consent	k-Anonymity, l-Diversity, t-Closeness for anonymization, Differential Privacy for data correlation, Synthetic data	[40, 93]
	33 & 34	Notifications and communicating the occurred breaches	End-to-End Encryption, Zero trust architecture, Secure multi-party computation	[40, 77]
Data storage and organizing	5	Data should not be kept in an identifiable form for longer than is necessary	Anonymization, pseudonymization	[93]
	25	Applied necessary techniques, such as pseudonymization, to safeguard the data	TLS/SSL encryption, Quantum cryptography, Secure API gateways	[77]
	17	Right to erasure ('right to be forgotten')	Restricting the duration of data storage, Smart contracts	[89, 91, 92]
	16	Right to rectification	Blockchain, Smart contracts	
	32 & 33	Applied necessary techniques, such as pseudonymisation, to safeguard the data. Also, Notifications and communicating the occurred breaches	Insider threat detection, Blockchainbased audit trails, Data access monitoring, zero trust security model	[77]
Data processing and analysis	25	Data protection	Privacy-preserving machine learning (PPML): Federated learning to prevent data leaks	[38, 39]
	9	sensitive data explicit consent	explicit consent from the data subject	[90]
	26	Joint controllers: responsibilities and arrangements when two or more parties jointly determine the purposes and means of processing personal data	Secure aggregation, Noise addition, Synthetic data generation	[39]
	35	Data protection impact assessment	pseudonymized	[40]
	6	Processing personal data Lawfully, fairly and in a transparent manner in relation to the data subject	Describing the type of data processing to the subject. The processing must meet what has been described. The Processing must meet the tests described	[89]
Data sharing and compliance issues	44 & 50	Data protection when transferring data to third party	Access control policies, Blockchain for data provenance, Smart contracts	[39, 77]
	7	User Consent Reqs	Automated consent management system, user-friendly data access controls, Smart contracts	[38, 92]

Table 8 NIST standards and privacy-preserving techniques for data trustworthiness

Category	NIST standard	Standard description	Privacy-preserving techniques	Reference
Data collection & integration	Special publication (SP 800-53)	Physical access and monitoring controls	Device authentication mechanisms, Role-Based Access Control (BAC)	[87]
		Cryptographic protection of data in transit	End-to-End encryption	[40]
		Identify, protect physical devices and system & detect		[81]
		Protect data in transit	Endpoint authentication using digital certificate	[80]
	SP800-82	Guidance for securing organizational control system	Role-Based Access Control (BAC)	[95]
	Risk management framework (RMF)	Choose & implement controls to protect device integrity & data confidently	Device Authentication Mechanisms	[81]
	SP800-207	Securing interactions between layers	Zero trust architecture	[96]
	SP 800-52 Rev. 2	Secure transport protocol		[97]
	Privacy Framework (PF)	Data minimization	Anonymization, pseudonymization	[77]
	CSF	Data privacy and data lifecycle is secure	Role-Based Access Control (BAC) or ABAC	[80]
Data management and analysis	SP800-53	Media sanitization and least privilege	Multi-Factor Authentication (MFA)	[87]
	SP800-122	Identify and handle data (PII, sensor data, operational data)	Federated learning to prevent data leaks	[98]
	SP800-171	Protect CUI in non-federal system	Federated learning to prevent data leaks	[96]
	SP800-207	Securing interactions between layers	Zero trust architecture	[99]
		Ensure models don't inadvertently re-identify individuals	Federated learning to keep training data local	[77]
	PF	De-identification and differential privacy	Synthetic data generation	[39]
	CSF	Make sure that the Software development lifecycle is secure		
		Software integrity validation and confidentiality	Homomorphic encryption to encrypt data	[87]
Data modeling	SP800-53	Algorithm transparency and user limitation	Audit logging and algorithmic transparency	[81]
	AI RMF	Map, measure and manage risks from AI analytics and management risks	Privacy-preserving machine learning (PPML)	[81]
	SP800-207	Securing interactions between layers	Zero trust architecture	[78, 99]

Table 8 continued

Category	NIST standard	Standard description	Privacy-preserving techniques	Reference
Model evaluation and verification	CSF	Managing cybersecurity risk by 5 main functions: (Identify, Protect, Detect, Respond, and Recover)	Federated learning to keep training data local	[80]
	SP800-207	Securing interactions between layers	Zero trust architecture	[78, 99]
	PF	Transparency and user control	User friendly data access controls, Blockchain for data provenance	[77]
Data sharing and compliance issues	CSF	Managing data sharing risk by 5 main functions: (Identify, Protect, Detect, Respond, and Recover)		[39]
	SP800-53	Interlock security, Session timeouts, audit logs	Session controls and timeout	[87]
	SP800-63	Access control & Strong authentication for users, User Consent Reqs	Automated consent management system	[100]
	SP800-207	Securing interactions between layers	Zero trust architecture	[78]

Relevant NIST standards and controls for DT:
1- Cybersecurity Framework (CSF) (General framework)
2- Privacy Framework (PF)
3- Risk Management Framework (RMF) (Operating in US federal context)
4- Interagency/Internal Report (IR) 8356, Security and Trust Considerations
5- Special Publication (SP) (800 series (52, 53 Rev. 5, 63 Rev. 3, 122, 171, 207))

ity, transparency, and trustworthiness. Thus, this mapping will enhance organization trust, technological robustness, and sustainable digital transformation.

3.4 Compliance Governance Structure

Establishing a comprehensive compliance governance structure is fundamental to effective compliance management in DT environments. Such a structure encompasses the creation of governance bodies and specialized committees tasked with overseeing compliance-handling processes, monitoring compliance status, and ensuring accountability across the organization. In addition, it integrates tools and technologies to support continuous compliance tracking, monitoring, and reporting to senior management.

The importance of this governance structure is underscored by several provisions of the GDPR. Articles 5(2), 24, 25, and 30 collectively emphasize the principles of accountability, record keeping, and data protection by design and by default. Article 39, where applicable, further delineates the responsibilities of the Data Protection Officer (DPO) within the governance framework. These provisions highlight the dual need for organizational oversight and technical measures. For instance, Article 24 requires data controllers to implement appropriate technical and organizational measures to demonstrate compliance, while Article 25 mandates that privacy safeguards be embedded in system design from the outset. Article 30 obliges organizations to maintain detailed records of processing activities, and Article 32 prescribes the adoption of security measures—such as encryption and access control—to protect personal data against unauthorized access, loss, or alteration.

Complementary guidance is provided by NIST standards, which emphasize the technical and procedural elements of compliance oversight. NIST IR 8356 explicitly recognizes the complexity of DT security and the necessity of dedicated governance structures. Similarly, NIST SP 800-53 prescribes a wide range of controls, including audit and accountability mechanisms, configuration management, vulnerability scanning, data integrity monitoring, and system configuration oversight, all of which contribute to compliance tracking [87]. The NIST-CSF further encourages the deployment of technologies that support the core security functions—protect, respond, and recover—while fostering a security-aware culture through training programs, awareness initiatives, and the integration of data privacy considerations throughout the DT lifecycle [80].

Table 9 Mapping of ISO's Principles to DT's Privacy Requirements

Category	ISO/IEC control	Control purpose	Privacy-preserving techniques	Reference
Data collection & integration	A.8.11 - Data masking	Minimize exposure of sensitive data during collection	Data masking, anonymization, pseudonymization	https://www.iso.org/standard/27001
	A.8.2 - Data classification	Classify information to ensure adequate protection levels	Metadata tagging, automated classification tools	https://www.iso.org/standard/27001
	A.5.15 - Access control policy	Restrict data access to authorized users only	RBAC, ABAC, multi-factor authentication (MFA)	https://doi.org/10.1016/j.future.2024.103115
	A.8.9 - Information Transfer	Ensure secure data transmission	End-to-End Encryption, TLS/SSL	https://www.nist.gov/cyberframework
Data storage & management	A.8.10 - Secure Disposal	Prevent data recovery after end-of-life	Cryptographic erase, secure wiping	https://doi.org/10.1109/MSEC.2024.3175047
	A.8.12 - Data leakage prevention	Avoid unauthorized data exfiltration	Data loss prevention (DLP), zero trust architecture, blockchain	https://doi.org/10.1016/j.cose.2024.102248
Data processing & analysis	A.5.10 - Acceptable Use Policy	Define rules for secure use of organizational data	Endpoint monitoring, user activity logging	https://www.iso.org/standard/27001
	A.8.34 - Protection of PII	Comply with legal obligations on personal data	Differential privacy, homomorphic encryption, PPML	https://doi.org/10.3390/su141912485
	A.5.17 - Authentication information	secure user credentials and identities	Password vaults, MFA, biometrics	https://www.iso.org/standard/27001
	A.8.16 - Monitoring activities	Detect misuse of sensitive information	Audit logs, SIEM systems, anomaly detection	https://www.nist.gov/it/ai-risk-management-framework
Data modeling & quality	A.8.35 - Data accuracy & quality	Maintain data reliability and precision	Data validation pipelines, automatic cleansing	https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final
	A.5.36 - Secure development lifecycle	Ensure security and privacy in development	Threat modeling, secure coding, privacy-by-design	https://www.iso.org/standard/27001
Model evaluation & assurance	A.8.26 - Independent Security Review	Conduct periodic privacy/security assessments	External audits, privacy impact assessments (PIA)	https://www.nist.gov/it/ai-risk-management-framework
	A.5.23 - Legal & regulatory compliance	Align with applicable privacy laws	Compliance monitoring, audit trails	https://doi.org/10.1016/j.cose.2024.102248
Data sharing & compliance	A.5.31 - Record protection	Prevent tampering or loss of records	Blockchain-based storage, immutable logs	https://doi.org/10.1109/MSEC.2024.3175047
	A.5.14 - Cryptography Policy	Standardize encryption practices	Homomorphic encryption, key lifecycle management	https://www.iso.org/standard/27001

Table 10 Consolidated mapping of regulatory requirements across digital twin functional Layers

DT layer	Core technologies	GDPR articles	NIST controls	ISO/IEC controls	Key compliance /mechanism in DTFRC
Layer 1: data collection & integration	IoT (sensors, cameras, actuators, edge devices)	Art. 5 (data minimization), Art. 7 (consent), Art. 9 (sensitive data), Art. 32 & 34 (breach notification)	SP 800-53 (access control), SP800-82, SP 800-207 (zero trust), CSF (identify & protect), SP 800-52 Rev.2, RMF, PF	A.8.11 (data masking), A.8.2 (data classification), A.5.15 (access control), A.8.9 (information transfer), A.5.14 (Encryption)	Consent validation, Access control, encryption in transit, secure device authentication
Layer 2: data management & analysis	Big data platforms, ML/DL, cloud infrastructure	Art. 5 (data identification), Art. 25 (data protection), Art. 17 (data deletion), Art. 16 (Data rectification), Art. 32 & 33 (data protection), Art.26 (control personal data)	SP 800-53 (access control), SP 800-207 (zero trust), SP 800-122, SP 800-171, CSF, PF	A.8.10 (secure disposal), A.8.12 (leakage prevention), A.5.10 (Use policy), A.8.34 (PII protection), A.5.17 (authentication), A.8.16 (monitoring activities)	Federated learning, authentication, encryption, differential privacy, risk assessment, data minimization, data governance, audit and monitoring
Layer 3: data modeling & quality	AI models, CAD/CAE, simulation engines, XAI tools	Art.25 data protection), Art.35 (impact assessment), Art.6 (data processing)	AI RMF, SP 800-53 (audit controls), SP 800-207 (Zero Trust)	A.8.35 (accuracy & quality), A.5.23 (regulatory compliance)	Explainability, audit and algorithmic transparency, Data validation, differential privacy, Federated learning
Layer 4: evaluation & verification	Audit logs, compliance engines, model validation tools	Art.34 (breach notification)	CSF (detect & respond), SP 800-207 (zero trust), PF	A.8.26 (security assessment), A.5.23 (regulatory compliance)	Continuous monitoring, audit, breach detection and response, automated compliance verification
Layer 5: visualization & virtualization	VR, AR, MR, HMIs, immersive dashboards	Art.44, Art.50, Art.7	CSF (Protect), SP 800-63 (Authentication), SP 800-53 (audit controls), SP 800-207 (zero trust)	A.5.23 (regulatory compliance), A.5.31 (recorded protection)	Biometric data protection, user consent transparency, privacy-by-design in XR

In parallel, ISO standards reinforce the role of governance in compliance adoption. ISO/IEC 27001:2022 calls for demonstrable leadership commitment and the establishment of governance structures within ISMS. ISO/IEC 27701:2019 extends this by defining specific governance roles for privacy management. The second sub-step, "Identify technology and tools for compliance tracking," aligns with ISO/IEC 27002:2022, which introduces controls for asset monitoring and information governance, and with ISO/IEC 27035:2023, which guides incident detection and response procedures to support compliance oversight. Finally, the third sub-step, "Develop strategies to facilitate compliance adoption," reflects ISO/IEC 27001:2022's emphasis on awareness, training, and operational support (Clause 7) and is further complemented by ISO/IEC 27004:2016, which outlines methodologies for developing metrics to ensure ongoing monitoring and adaptive compliance [82, 101, 102]. In light of these frameworks, the study outlines three governance mechanisms that support the adoption of the proposed compliance governance structure. These mechanisms aim to support the integration of regulatory compliance considerations within the governance structure of digital twin systems.

3.4.1 Establish Governance Bodies to Oversee Compliance Efforts

Dedicated governance bodies play a critical role in supporting the effectiveness and consistency of regulatory compliance within DT systems. Such governance bodies support continuous oversight of compliance status and promote alignment with data protection, cybersecurity, and organizational policies. By embedding structured oversight, organizations can institutionalize accountability and transparency in their compliance practices. Governance structures of this kind are directly supported by international frameworks. Under the GDPR, Articles 24 and 25 emphasize the controller's accountability and data protection by design, while Article 30 requires maintaining detailed records of processing activities, and Article 39 outlines the supervisory role of the Data Protection Officer (DPO). These provisions establish a legal basis for governance bodies that oversee accountability, record keeping, and privacy by design in DT systems. NIST further complements this foundation by providing technical and operational guidance. For instance, NIST IR 8356 highlights the need for oversight of DT-specific trust and security concerns, while NIST SP 800-53 introduces audit and accountability controls, configuration management, and monitoring mechanisms to support compliance tracking [87]. In addition, NIST-CSF reinforces governance efforts by promoting a culture of security awareness through its Protect, Respond, and Recover functions [80]. At the international level, ISO/IEC 27001:2022 mandates leadership commitment and governance within the ISMS, and ISO/IEC 27701:2019 extends these requirements to privacy-specific roles. Complementary standards, such as ISO/IEC 27002:2022, ISO/IEC 27035:2023, and ISO/IEC 27004:2016, provide controls for monitoring, incident response, and compliance metrics [82, 101, 102]. In practice, organizations are encouraged to establish a *Digital Twin Regulatory Compliance Committee* (DTRCC) as the central governance body. The DTRCC would be tasked with enforcing the *Digital Twin Framework for Regulatory Compliance* (DTFRC), evaluating compliance effectiveness, identifying and mitigating risks, and reporting to the appointed *Digital Twin Chief Privacy and Compliance Officer* (DTCPCO). Its multidisciplinary composition—spanning legal, IT security, data privacy, engineering, business units, and domain-specific compliance officers—ensures a holistic perspective on compliance oversight. Regular meetings should be held to review incident reports, update policies, address regulatory changes, and audit DT systems for compliance gaps [103–105]. The appointment of a DTCPCO is essential for organizational accountability. This officer acts as the liaison with external regulatory authorities, thereby operationalizing GDPR's accountability principle and NIST's emphasis on audit and oversight, while reporting directly to executive leadership or the Board of Directors [106]. To further embed ethical considerations, particularly in AI-driven or predictive analytics applications, a *Digital Twin Data Ethics Advisory Board* (DTDEAB) should be established. This body would evaluate high-risk use cases, ensure fairness, transparency, and accountability in data use, and align ethical oversight with ISO/IEC 29100 privacy principles. Integrating these governance structures into the DT development lifecycle ensures that compliance and privacy requirements are addressed proactively rather than reactively. By linking GDPR's legal obligations, NIST's technical and operational safeguards, and ISO's internationally harmonized best practices, organizations can establish a resilient governance model. Such integration not only ensures adherence to current regulations but also enables anticipation of regulatory modifications and effective responses to emerging challenges. Table 11 summarizes the responsibilities of the proposed governance bodies and their reporting lines. Following the definition of governance bodies, it is necessary to map the roles and responsibilities of stakeholders involved in DT compliance. Table 12, adapted from [107] and refined, identifies DT stakeholders—such as data subjects, controllers, and third parties—and categorizes their roles within the compliance framework. This mapping clarifies accountability and ensures that responsibilities are consistently distributed across organizational levels.

Taken collectively, the GDPR, NIST, and ISO frameworks provide complementary yet distinct contributions to the design of compliance governance in DT systems. GDPR

establishes the legal and ethical obligations of accountability, privacy by design, and record keeping, thereby defining what must be achieved. NIST frameworks translate these obligations into actionable technical and operational safeguards, offering controls for audit, monitoring, trust, and incident response that detail how compliance can be operationalized. ISO standards, in turn, provide internationally harmonized benchmarks and best practices, ensuring that governance structures are implemented consistently across industries and jurisdictions. By integrating these three perspectives—legal (GDPR), technical (NIST), and international best practice (ISO)—organizations can develop governance models that are both robust and adaptive, capable of addressing current regulatory requirements while anticipating future challenges.

3.4.2 Identify Technology and Tools for Compliance Tracking Adoption

The effective enforcement of compliance tracking in DT systems requires the integration of appropriate technologies and tools capable of supporting automation, monitoring, and reporting. Compliance management platforms play a central role in this process, as they enable the automation of compliance monitoring activities and facilitate the generation of systematic reports for organizational oversight [108]. In parallel, robust data protection mechanisms are essential to safeguard sensitive information and ensure alignment with privacy regulations. Core measures include encryption, access control, and authentication protocols, which provide the foundational security necessary for compliance. More advanced approaches, such as Role-Based Access Control (RBAC) and Multi-Factor Authentication (MFA), further enhance data confidentiality and integrity by restricting unauthorized access and strengthening identity verification. Privacy-preserving techniques also represent a vital component of compliance tracking. Methods such as federated learning and differential privacy allow organizations to process and analyze data while minimizing risks of exposure, thereby maintaining adherence to stringent regulations such as the GDPR. Finally, monitoring and reporting tools provide the capability to perform continuous assessments of compliance status, issuing alerts and notifications in cases of deviation from established regulatory requirements [109]. The adoption of these technologies is directly supported by existing regulatory and standardization frameworks. Under the GDPR, Article 32 explicitly requires the implementation of appropriate technical measures, including encryption and access controls, to ensure the security of personal data during processing. NIST further reinforces this requirement through its CSF, which emphasizes continuous monitoring and incident response as core functions, and through SP 800-53, which prescribes controls for logging, auditing, and system integrity verification. Similarly, ISO standards provide internationally harmonized best practices: ISO/IEC 27002:2022 outlines controls for access management and system monitoring, while ISO/IEC 27035:2023 specifies incident detection and response procedures. Collectively, these frameworks ensure that compliance tracking tools are not only technologically robust but also aligned with recognized legal, technical, and international best practices.

3.4.3 Develop Strategies to Facilitate Compliance Adoption

Once governance bodies have been established and the necessary technologies and tools for compliance tracking identified, it becomes essential to design and implement strategies that support the adoption of compliance practices across the organization. The objective is not only to ensure procedural adherence but also to foster a culture of regulatory awareness and accountability. Building organizational readiness in this manner strengthens resilience and enhances the sustainability of compliance efforts. Within the governance model, structured training and awareness programs (e.g., workshops, e-learning modules, and targeted communication campaigns) are identified as mechanisms through which organizations can embed DT-related security and privacy requirements into practice [110]. Equally important are **clear communication channels** that disseminate compliance policies and expectations consistently across all organizational levels through official documentation, internal portals, and other communication platforms. The framework conceptually situates compliance within organizational change management, so that DT-related regulatory implications are analytically evaluated when new initiatives or system modifications are considered, thereby integrating compliance considerations into the organization's operational lifecycle. The model further suggests that performance indicators (KPIs) linked to compliance-relevant behaviors can function as governance levers for sustaining long-term regulatory adherence [111].

The adoption of these strategies is strongly reinforced by established frameworks. GDPR Article 39 emphasizes the importance of training and awareness under the responsibilities of the Data Protection Officer (DPO), while Article 25 (privacy by design) requires embedding compliance considerations into change management processes. NIST's CSF highlights the role of awareness and training in fostering a security-conscious culture, and its "Respond" and "Recover" functions encourage communication planning and resilience-building across the organizational structure. Similarly, ISO/IEC 27001:2022 (Clause 7) underscores the need for competence, awareness, and communication, while ISO/IEC 27004:2016 provides methodologies for measuring and improving the effectiveness of compliance adoption programs. By aligning strategies with these frameworks, organizations can ensure that compliance is not merely pro-

Table 11 Governance roles and responsibilities

Governance body/role	Report to	Key responsibilities
Board of directors / executive leadership	N/A	Strategic management, resource allocation, and absolute authority on compliance cases
DT chief privacy and compliance officer (DTCPCO)	Board of directors / executive leadership	Supervises all DT regulatory compliance and guides the compliance vision
Digital twin regulatory compliance committee (DTRCC)	DTCPCO	Enforces DTFRC, audits, evaluates incidents, revises policy, and reports risks
Digital twin data ethics advisory board (DTDEAB)	DTCPCO	Guides data ethical use, evaluates risks related to AI, and assures transparency and fairness
Legal representatives (in DTRCC)	DTRCC	Analyze legal frameworks and report on compliance with laws and agreements
IT security representatives (in DTRCC)	DTRCC	Manage cybersecurity controls, threat monitoring, and NIST/ISO implementation
Data privacy experts (in DTRCC)	DTRCC	Ensure GDPR compliance, manage personal data, and assess privacy consequences
Engineering leads (in DTRCC)	DTRCC	Align technical approaches with compliance standards and secure architectures
Business unit representatives (in DTRCC)	DTRCC	Integrate compliance into business procedures and workflows
Domain-specific compliance officers (in DTRCC)	DTRCC	Monitor industry-specific regulation compliance (e.g., HIPAA, OSHA)

cedural but becomes an integral component of organizational culture and operational practice.

Taken together, the three governance steps—establishing dedicated governance bodies, identifying appropriate technologies and tools for compliance tracking, and developing strategies to facilitate compliance adoption—form a comprehensive compliance governance model for DT systems. Governance bodies provide the structural oversight and accountability mechanisms necessary to ensure alignment with regulatory obligations. Compliance technologies operationalize these structures by enabling monitoring, reporting, and privacy-preserving data management. Finally, adoption strategies embed compliance into the organizational culture, ensuring that regulatory awareness, training, and communication are sustained across all levels of the enterprise. When aligned with the principles of the GDPR, the technical safeguards of NIST, and the globally harmonized best practices of ISO, these three steps create a governance framework that is both robust and adaptive, capable of addressing evolving regulatory requirements while supporting the secure and trustworthy deployment of Digital Twin technologies.

To conceptualize how the proposed DT Privacy Regulatory Compliance framework can be internalized within organizations, the study models a structured Security Education, Training, and Awareness (SETA) component that links culture, communication, training, and supporting tools. SETA offers a comprehensive strategy for creating compliance competency across all roles within the organization, assuring alignment between technical implementation and regulatory commitments and ethical standards [112, 113]. The framework incorporates SETA-based mechanisms that support compliance adoption through the following components:

1. Security education: Security education is characterized as providing foundational understanding of regulatory frameworks (e.g., GDPR, NIST, ISO/IEC 27001, and sector-specific standards) to the diverse roles involved in the development, implementation, and operation of DT systems. Education should introduce the regulatory requirements and legal significance of non-compliance, as well as the proposed Digital Twin Framework for Regulatory Compliance (DTFRC), and all relevant ethical principles related to data processing.
2. Security training: Security training is framed as role-specific capability building focused on applying privacy-preserving technologies, engaging with governance artifacts (e.g., compliance dashboards, standard operating procedures, incident response playbooks), and aligning technical practices with DT-oriented data governance policies. This training should be compulsory for DTRCC members, compliance officers, and other relevant bodies.
3. Security awareness: Within the framework, awareness is conceptualized as ongoing communication activity (e.g., internal messaging and illustrative DT-related cases) that normalizes privacy-by-design principles and supports ethical decision-making in day-to-day operations. Additionally, awareness should promote the "privacy by

Table 12 Mapping of digital twin (DT) governance bodies and stakeholders

Stakeholders	Stakeholders role	GDPR article(s)	NIST standard	ISO/IEC control	Governance body
Data subject	Individual whose personal data is processed. Has rights (access, erasure) and can participate in NIST-RMF authorization	Art. 12-15	NIST SP 800-XX	ISO/IEC 29151:2017 (Privacy Provisions)	N/A
Data controller	Determines purposes/means of processing. Responsible for compliance, lawful processing, transparency, and data minimization	Art. 4, Art. 5, 7, 25	NIST SP 800-XX	ISO/IEC 27701:2019 (PIMS) ISO/IEC 27001:2022 (ISMS)	DTRCC & DTDEAB
Data controller/ compliance officer/ Auditor	A person/agency responsible for ensuring compliance, transparency, and data governance	Art. 5(2), 7, 27, 30, 32-35, 37, 40, 65, 77, 81, 83-85	CSF, PII, PMF, SP800	ISO/IEC 27701:2019 (PIMS) ISO/IEC 27002:2022 (ISC) ISO/IEC 27001:2022 (ISMS)	DTRCC & DTDEAB
Joint controllers	Two or more controllers jointly determine purposes and means. Must transparently define responsibilities (Art. 26)	Art. 26	N/A	ISO/IEC 27701:2019 (PIMS)	DTRCC & DTDEAB
Data processor	Processes data on behalf of the controller. Must follow instructions and implement technical/organizational measures	Art. 4(8), 28, 29	N/A	ISO/IEC 27701:2019 (PIMS) ISO/IEC 27002:2022 (ISC) ISO/IEC 29151:2017 (Privacy Frameworks) PII (Public Clouds)	DTRCC & DTDEAB and relevant team leads

Table 12 continued

Stakeholders	Stakeholders role	GDPR article(s)	NIST standard	ISO/IEC control	Governance body
Sub-processor	A third-party engaged by the processor. Relationship regulated by contract stipulations	Art. 28(2-4)	N/A	ISO/IEC 27701:2019 (PIMS) ISO/IEC 27002:2022 (ISC) ISO/IEC 29151:2017 (Privacy Frameworks) PII (Public Clouds)	DTRCC & DTDEAB
Data Protection Officer (DPO) / SOC Team	Provides advice, conducts impact assessments, and acts as a contact point. Implements continuous monitoring and incident response	Art. 37-39	F1, SP800	ISO/IEC 27701:2019 (PIMS) ISO/IEC 27002:2022 (ISC) ISO/IEC 27001:2022 (ISMS) ISO/IEC 27004:2016 (Monitoring) ISO/IEC 27035:2023 (Incident Mgt)	DTRCC & DTDEAB
Supervisory authority / CISO	Independent public authority overseeing GDPR enforcement. CISO checks security/privacy governance and warns organizations with NIST standards	Art. 51-58	CSF, PII, PMF, SP800	ISO/IEC 27701:2019 (PIMS) ISO/IEC 27002:2022 (ISC) ISO/IEC 27001:2022 (ISMS)	DTCPCO
Recipient / Third Party	Entity to whom personal data is disclosed. Must receive documented safeguards	Art. 49(1)(d)	N/A	ISO/IEC 29151:2017 (Privacy Frameworks) ISO/IEC 27701:2019 (PIMS)	DTRCC & DTDEAB
DevOps / Engineers	Implement secure code and secure deployment processes. Request prior controller authorization. Runs secure SDLC aligned with SP800	N/A	SP800	ISO/IEC 27004:2016 (App Sec) ISO/IEC 27002:2022 (ISMS)	DTRCC & DTDEAB

design" concept and foster ethical decision-making in everyday processes. Awareness efforts should empower employees to recognize and report compliance risks, thereby fostering a strong governance culture [114].

4. Supportive tools and governance: To reinforce SETA-driven compliance adoption, organizations should also implement the following to support the governance structures:
   - DT Standard Operating Procedures (DTSOPs) for data handling and review of regulatory compliance.
   - DT Regulatory Compliance Dashboards for managing, coordinating, and real-time monitoring and reporting using governance, risk, and compliance software (GRC).
   - DT Incident Response Playbooks for efficiently managing privacy violations.

Integration of SETA into onboarding processes and annual compliance audits will enhance trust and reduce regulatory risk (Fig. 6).

3.5 Compliance Metrics for Regulatory Evaluation

An essential step in establishing a robust compliance governance model for DT systems is the definition of measurable compliance metrics. Developing such metrics enables organizations to assess adherence, monitor progress, and ensure accountability through structured, verifiable methods. ISO/IEC 27004:2016 provides explicit guidance for creating quantifiable security metrics, while ISO/IEC 27701:2019 extends these practices to privacy-specific performance indicators. Although the GDPR does not prescribe explicit compliance metrics, it emphasizes the requirement for demonstrable compliance. Article 5(2) introduces the accountability principle, requiring controllers not only to comply with the regulation but also to provide evidence of such compliance. Article 24 reinforces this obligation by mandating the implementation and documentation of technical and organizational measures proportionate to processing risks. Similarly, Article 30 requires the maintenance of records of processing activities, while Article 35 establishes the use of Data Protection Impact Assessments (DPIAs) as a structured mechanism for evaluating risks and assessing the effectiveness of adopted measures. The establishment of compliance metrics fulfills several objectives:

1. Providing a structured framework to evaluate compliance status in a transparent and repeatable manner.
2. Identifying gaps in existing practices and highlighting areas requiring immediate remediation.
3. Enhancing organizational practices by strengthening data handling procedures, refining security protocols, and improving incident response planning.

To analytically structure these objectives, the framework represents compliance metrics in a checklist-like schema. Table 13 exemplifies how DT-specific metrics can be mapped to legal (GDPR) and technical-operational (NIST, ISO) requirements. The checklist addresses critical DT dimensions, including data encryption, data minimization, access control, consent management, auditing, risk assessment, incident response, third-party compliance oversight, and employee training. Each item functions as an indicator that can be associated with relevant GDPR articles, NIST standards, and ISO controls, and the schema conceptually assigns responsible roles to illustrate how accountability for these indicators may be structured in DT settings.

3.6 Continuous Compliance Improvement

Building on the previously defined governance structures, compliance tools, adoption strategies, and measurable metrics, the final step is to ensure that the framework remains dynamic through continuous feedback and improvement. To validate the proposed framework, it is essential to seek professional review and gather structured feedback. Insights from industry experts will help identify limitations, highlight areas for enhancement, and ensure that the framework remains robust and aligned with best practices. Professional input can also guide refinements to compliance procedures and policies, thereby strengthening their applicability and effectiveness.

To support continuous improvement, the framework incorporates a feedback mechanism that leverages surveys, structured reviews, and other feedback tools to capture input from employees, stakeholders, and compliance professionals. This input not only identifies areas requiring refinement but also informs the evolution of future compliance strategies. Regular review cycles are necessary to update policies and procedures in response to professional feedback, evolving regulatory requirements, and shifting industry standards. Scheduled consultations with professionals further reinforce the framework's adaptability, ensuring its relevance amid ongoing technical and regulatory changes.

Although the concepts of "feedback" and "continuous improvement" are not explicitly articulated in the GDPR, they are embedded within its core principles and obligations. Article 5(2) establishes accountability, requiring controllers to demonstrate an ongoing commitment to effective data protection. Article 24 calls for technical and organizational measures that are proportionate and regularly updated to reflect changing risks. Article 32 mandates regular testing, assessment, and evaluation of security measures, thereby

Table 13 Compliance alignment matrix

Key aspect	Checklist item	GDPR article	NIST	ISO/IEC 27001:2022	Responsible role	Status
Data encryption	Encrypt data by using up-to-date encryption algorithms for all data and communication channels	Art. 32, 33, 34	SP 800-53 SC-12, SP800-232, CSF	A.10.1 - Cryptographic Controls: Ensure proper and effective use of encryption to protect confidentiality, integrity, and availability	Data Processor, IT Security Team	
Data minimization	Collect and store only essential data necessary for the digital twin's purpose	Art. 5	PF DM-P	A.5.1 - policies for information security: define and apply data collection and retention policies aligned with business and legal needs	Data protection officer (DPO), data controller	
Data access control & identity management	Define roles with least privilege for users and automated systems, enable MFA, RBAC for all admin and privileged accounts, regularly review and update access permissions	Art. 5, 32	SP 800-53 AC-2(11), SP 800-82, CSF	A.8.1 - user access management; A.5.15 - access control: restrict access to authorized individuals only	IT security operations team (IT/SOC), CISO	
Consent management	implement friendly interfaces to request and manage consent (user consent request, right to erasure)	Art. 7, 9, 17	PF TR-P, SP800-63B, SP800-122	A.5.34 - privacy and protection of PII: Ensure PII processing is lawful, fair, and transparent	Data controller, data processor	
Regular audit & vulnerability testing	Enable audit logs for access/data modifications, do regular penetration testing for DT system, conduct security assessments, and ensure compliance	Art. 30, 33	SP 800-53 AU-2	A.5.28 - Logging; A.8.8 - management of technical vulnerabilities: identify and address system weaknesses	Data controller/compliance officer/auditor, IT security	

Table 13 continued

Key aspect	Checklist item	GDPR article	NIST	ISO/IEC 27001:2022	Responsible role	Status
Data risk assessment & management	Conduct regular DPIAs, identify threats and vulnerabilities, and develop mitigation strategies	Art. 35	SP 800-37, SP800-231, RMF	A.5.4 - information security risk assessment: continuously assess and treat information security risks	Data protection officer (DPO), CISO or risk manager	
Data breach & incident response	Establish a tested incident response plan including breach notification, detection, prioritization, analysis, and recovery	Art. 33	SP 800-61, CSF	A.5.24 - incident management planning; A.5.25 - response to incidents	Data controller, compliance officer, auditor, CISO	
Data Monitoring	Continuously monitor access logs and network traffic using advanced tools and AI/ML for anomaly detection	Art. 32, 33	SP 800-53B, CSF	A.5.27 - monitoring activities: monitor systems and user activities to detect suspicious behavior and ensure compliance	DPO, IT/SOC Team, CISO	
vendor & third-party compliance management	Automatically assess, enforce, and document vendor compliance with GDPR, NIST, and ISO standards	Art. 28, 44, 50	SP 800-171A	A.5.22 - managing information security in ICT supply chain	DPO, CISO	
Employee training & awareness	Implement department-wide policy acknowledgments and regulatory training	Art. 39	SP 800-50 Rev.1	A.6.3 - awareness, education and training: promote a security-conscious culture	DPO, HR, compliance officer	

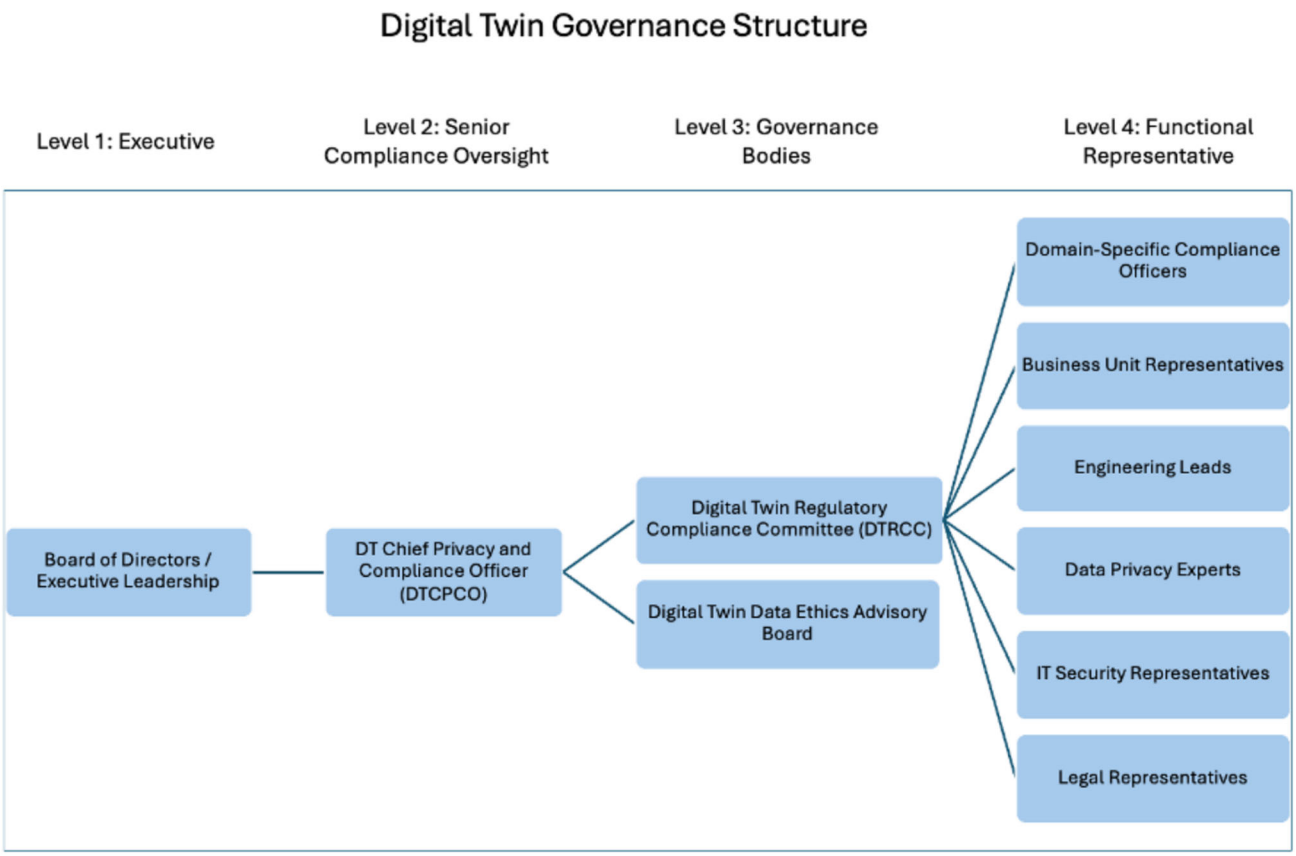


Fig. 6 Digital twin governance structure

implicitly supporting iterative improvement. Article 35 introduces Data Protection Impact Assessments (DPIAs), which provide a structured mechanism for identifying risks and informing corrective action. In addition, Article 39 assigns the Data Protection Officer (DPO) the responsibility of monitoring compliance and advising on improvements, reinforcing the need for a feedback-driven compliance process.

The NIST-CSF similarly embeds continuous improvement across its five core functions—identify, protect, detect, respond, and recover—each of which is designed to operate iteratively. The CSF promotes regular assessments, penetration testing, and structured reviews as mechanisms for generating feedback and updating security policies and procedures [80]. ISO standards also emphasize iterative refinement: ISO/IEC 27001:2022 (Clause 10) requires periodic reviews and corrective actions, while ISO/IEC 27005:2022 highlights iterative risk reassessment and system adjustments based on feedback and performance monitoring [82, 88].

In summary, Fig. 5 illustrates a holistic pathway for implementing regulatory compliance in DT environments by integrating GDPR's legal principles, NIST's operational safeguards, and ISO's internationally harmonized standards across governance, technical controls, risk management, and continuous improvement. By embedding feedback mechanisms into each stage, the framework becomes cyclical rather than linear, ensuring that insights from practice continuously inform governance, tools, strategies, and metrics, thereby sustaining regulatory alignment and resilience over time.

4 Conclusion

This study conducted a systematic literature review to examine the regulatory compliance landscape of Digital Twin (DT) systems and identify gaps in the alignment of DT technologies with current legal and technical requirements. The findings highlight a critical need for compliance measures to be embedded throughout the DT lifecycle rather than treated as isolated or post-implementation activities. In response, this paper proposes a comprehensive, multi-layer Digital Twin Framework for Regulatory Compliance (DTFRC) that integrates privacy, security, and governance controls across DT functional components. By unifying legal, technical, and organizational perspectives, this research contributes a structured foundation for designing secure, transparent, and regulation-aware DT systems that align with international standards and promote accountability and user trust. While the framework extends current knowledge in this

area, future work is required to validate its applicability across industry domains, assess its operational effectiveness in real-world deployments, and evolve the model alongside emerging global regulatory requirements.

4.1 Limitations and Future Directions

The primary limitation of this study is that the proposed Digital Twin Framework for Regulatory Compliance (DTFRC) is conceptual and has not yet been empirically validated in real-world Digital Twin deployments. While the framework was systematically developed based on regulatory analysis and findings from the Systematic Literature Review (SLR), its practical effectiveness, scalability, and adaptability across different industrial contexts remain to be evaluated. Currently, the authors are working on reviewing and gathering structured feedback from a panel of subject matter experts. The evaluation examines compliance alignment with GDPR, NIST, and ISO standards, organizational readiness, governance maturity, and the operational impact of adopting DTFRC. Additionally, the framework provides a governance and compliance structure but does not prescribe specific technical implementations or automated mechanisms for compliance monitoring and enforcement. The future work will involve implementing and validating the proposed compliance governance framework digital twin (DTFRC) in practical settings across various industries. To address the framework practical limitation, the authors will develop a detailed case study to implement and test the conceptual framework in a practical environment. The outcome of this empirical validation will be reported in a forthcoming publication.

Designing a robust risk assessment process is one of the future research areas to identify the privacy threat during the use of the DT at multiple stages, including data acquisition, ingestion, processing, and synthesis. Another potential of research is to integrate the agentic artificial intelligence (AI) to enhance privacy management in DTs. Trained machine learning models are used on synthetic or anonymized data with non-compliance activities, such as privacy violations, to be capable of initiating automated responses, such as compliance alerts, or data masking. In addition to these technical developments, another potential area of future work is to develop a user-centric platform that collects and evaluates consent mechanisms, promoting transparency and user control. With proper usability testing and feedback, various approaches will be assessed to determine the efficacy in maintaining continuing user engagement.

Funding The authors declare that this research received no external funding.

Declarations

Ethical approval This study did not involve any human participants, animals, or sensitive personal data. Therefore, ethical approval and informed consent were not required.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adaptation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit http://creativecommons.org/licenses/by/4.0/.

References

1. Botín-Sanabria, D.M.; Mihaita, A.-S.; Peimbert-García, R.E.; Ramírez-Moreno, M.A.; Ramírez-Mendoza, R.A.; Lozoya-Santos, Jd.J.: Digital twin technology challenges and applications: A comprehensive review. Remote Sens **14**(6), 1335 (2022)
2. Alcaraz, C.; Lopez, J.: Digital twin: A comprehensive survey of security threats. IEEE Communi. Surv. Tutorials **24**(3), 1475–1503 (2022)
3. Wang, Y.; Su, Z.; Guo, S.; Dai, M.; Luan, T.H.; Liu, Y.: A survey on digital twins: Architecture, enabling technologies, security and privacy, and future prospects. IEEE Internet Things J. **10**(17), 14965–14987 (2023)
4. Omrany, H.; Al-Obaidi, K.M.; Husain, A.; Ghaffarianhoseini, A.: Digital twins in the construction industry: a comprehensive review of current implementations, enabling technologies, and future directions. Sustainability **15**(14), 10908 (2023)
5. Kitchenham, B.; Brereton, O.P.; Budgen, D.; Turner, M.; Bailey, J.; Linkman, S.: Systematic literature reviews in software engineering-a systematic literature review. Inf. Softw. Technol. **51**(1), 7–15 (2009)
6. Kitchenham, B.; Pretorius, R.; Budgen, D.; Brereton, O.P.; Turner, M.; Niazi, M.; Linkman, S.: Systematic literature reviews in software engineering-a tertiary study. Inf. Softw. Technol. **52**(8), 792–805 (2010)
7. Firmansyah, B.; Arman, A.A.: A systematic literature review of regtech: Technologies, characteristics, and architectures. In: 2022 International Conference on Information Technology Systems and Innovation (ICITSI), pp. 310–315. IEEE (2022)
8. Naqvi, B.; Perova, K.; Farooq, A.; Makhdoom, I.; Oyedeji, S.; Porras, J.: Mitigation strategies against the phishing attacks: A systematic literature review. Comput. Security **132**, 103387 (2023)
9. Imam, N.H.: Adversarial examples on xai-enabled dt for smart healthcare systems. Sensors **24**(21), 6891 (2024)
10. Esiri, A.E.; Sofoluwe, O.O.; Ukato, A.: Digital twin technology in oil and gas infrastructure: Policy requirements and implementation strategies. Eng. Sci. Technol. J. **5**(6), 2039–2049 (2024)
11. Czekster, R.M., Garcia Perez, A., Kavakli-Thorne, M., El Mesloul Nasri, S.A., Shaikh, S.: Cyber-physical and business perspectives using federated digital twins in multinational and multimodal transportation systems. arXivpreprint arXiv:2410.08479 (2024). https://doi.org/10.48550/arXiv.2410.08479

12. Armeni, P., Polat, I., De Rossi, L.M., Diaferia, L., Visioli, G., Meregalli, S., Gatti, A.: Digital twins for health: Opportunities, barriers and a path forward. In: Korhan, O. (ed.) Digital Twin Technology: Fundamentals and Applications, pp. 43–65. IntechOpen, London (2023). https://doi.org/10.5772/intechopen.112490
13. Fakhraian, E., Semanjski, I., Semanjski, S., Aghezzaf, E.-H.: Towards safe and efficient unmanned aircraft system operations: Literature review of digital twins' applications and European Union regulatory compliance. Drones **7**(7), 478 (2023). https://doi.org/10.3390/drones7070478
14. Eswaran, U., Eswaran, V., Murali, K., & Eswaran, V. (2024). Predictive healthcare analytics. In A. Dubey, C. K. K. Reddy, & S. Doss (Eds.), Exploring the advancements and future directions of digital twins in Healthcare 6.0 (pp.171–199). IGI Global Scientific Publishing. https://doi.org/10.4018/979-8-3693-5893-1.ch009
15. Vaghani, B.M.: Digital twin-ai based risk assessment and quality assurance in the medical device lifecycle. Emerg. Healthcare Eng. 1–12 (2024)
16. Rahmadian, E.; Feitosa, D.; Virantina, Y.: Digital twins, big data governance, and sustainable tourism. Ethics Inf. Technol. **25**(4), 61 (2023)
17. Bakare, O.; Aziza, O.; Uzougbo, N.; Oduro, P.: A governance and risk management framework for project management in the oil and gas industry. Open Access Res. J. Sci. Technol. **12**(01), 121–130 (2024)
18. Giel, R., Werbinska-Wojciechowska, S., Winiarska, K.: Technical and organizational challenges in designing a testbed for an internal transport system necessary for developing a digital twin. Sensors and Electronic Instrumentation Advances, pp. 172–175 (2024)
19. Azambuja, A.J.G.; Giese, T.; Schützer, K.; Anderl, R.; Schleich, B.; Almeida, V.R.: Digital twins in industry 4.0-opportunities and challenges related to cyber security. Procedia Cirp **121**, 25–30 (2024)
20. Otoom, S.: Risk auditing for digital twins in cyber physical systems: A systematic review. J. Cyber Security Risk Auditing **2025**(1), 22–35 (2025)
21. Alhumam, N., Rahman, M.H., Aljughaiman, A.: A comprehensive review on cybersecurity of digital twins issues, challenges, and future research directions. IEEE Access **13**, 45106–45124 (2025). https://doi.org/10.1109/ACCESS.2025.3545004
22. Raitviir, C.-R.; Lill, I.: Conceptual framework of information flow synchronization throughout the building lifecycle. Buildings **14**(7), 2207 (2024)
23. Minerva, R.; Lee, G.M.; Crespi, N.: Digital twin in the iot context: A survey on technical features, scenarios, and architectural models. Proc. IEEE **108**(10), 1785–1824 (2020)
24. Homaei, M., Gutiérrez, O.M., Núñez, J.C.S., Vegas, M.A., Lindo, A.C.: A review of digital twins and their application in cybersecurity based on artificial intelligence. arXiv preprint arXiv:2311.01154 (2023). https://doi.org/10.48550/arXiv.2311.01154
25. Lu, Y.; Liu, C.; Kevin, I.; Wang, K.; Huang, H.; Xu, X.: Digital twin-driven smart manufacturing: Connotation, reference model, applications and research issues. Robot. Comput.-Int. Manuf. **61**, 101837 (2020)
26. Bevilacqua, M.; Bottani, E.; Ciarapica, F.E.; Costantino, F.; Di Donato, L.; Ferraro, A.; Mazzuto, G.; Monteriù, A.; Nardini, G.; Ortenzi, M., et al.: Digital twin reference model development to prevent operators' risk in process plants. Sustainability **12**(3), 1088 (2020)
27. Iliuţă, M.E.; Moisescu, M.A.; Pop, E.; Mitulescu, T.C.: Risk assessment for digital twins applied in systems medicine. In: International Workshop on Service Orientation in Holonic and Multi-Agent Manufacturing, pp. 89–101. Springer (2023)
28. Barati, M.; Rana, O.; Petri, I.; Theodorakopoulos, G.: Gdpr compliance verification in internet of things. IEEE access **8**, 119697–119709 (2020)
29. Barati, M.; Petri, I.; Rana, O.F.: Developing gdpr compliant user data policies for internet of things. In: Proceedings of the 12th IEEE/ACM International Conference on Utility and Cloud Computing, pp. 133–141. (2019)
30. Esther, C.; GB, Z.S.; Tamizhmalar, D.; Dhinakaran, D.; et al.: Trustworthy cloud storage data protection based on blockchain technology. In: 2022 International Conference on Edge Computing and Applications (ICECAA), pp. 538–543 (2022). IEEE
31. Dhinakaran, D.; Lakshminarayanan, S.; Selvaraj, D.: Secured and privacy-preserved aggregation of data in edge computing using blockchain-based secured aggregation (bsa). In: Convergence of Cybersecurity and Cloud Computing, pp. 131–164. IGI Global Scientific Publishing (2025)
32. Kumar, D.; Shankar, B.P.; Vennila, G.; Senthil, P.: Multiple precision arithmetic with blowfish crypto method for medical data storage using blockchain technology. In: 2023 International Conference on Innovative Computing, Intelligent Communication and Smart Electrical Systems (ICSES), pp. 1–6. IEEE (2023)
33. Alamri, B., Javed, I.T., Margaria, T.: A gdpr-compliant framework for iot-based personal health records using blockchain. In: 2021 11th IFIP International Conference on New Technologies, Mobility and Security (NTMS), pp. 1–5 (2021). https://doi.org/10.1109/NTMS49979.2021.9432661
34. Rantos, K.; Drosatos, G.; Demertzis, K.; Ilioudis, C.; Papanikolaou, A.; Kritsas, A.: Advocate: a consent management platform for personal data processing in the iot using blockchain technology. In: Innovative Security Solutions for Information Technology and Communications: 11th International Conference, SecITC 2018, Bucharest, Romania, November 8-9, 2018, Revised Selected Papers 11, pp. 300–313 (2019). Springer
35. Truong, N.B.; Sun, K.; Lee, G.M.; Guo, Y.: Gdpr-compliant personal data management: A blockchain-based solution. IEEE Trans. Inf. Forensics Secur. **15**, 1746–1761 (2019)
36. Rathore, M.M.; Shah, S.A.; Shukla, D.; Bentafat, E.; Bakiras, S.: The role of ai, machine learning, and big data in digital twinning: A systematic literature review, challenges, and opportunities. IEEE Access **9**, 32030–32052 (2021)
37. Wang, W. Y.; Yin, J.; Chai, Z.; Chen, X.; Zhao, W.; Lu, J.; Sun, F.; Jia, Q.; Gao, X.; Tang, B.; Hui, X.; Song, H.; Xue, F.;Liu, Z. K.; Li, J. Big data-assisted digital twins for the smart design and manufacturing of advanced materials: from atoms to products. J. Mater. Inf. (2022). https://doi.org/10.20517/jmi.2021.11
38. Kuštelega, M.; Mekovec, R.; Shareef, A.: Privacy and security challenges of the digital twin: systematic literature review. J. Univ. Comput. Sci. **30**(13), 1782 (2024)
39. Fernandez, I.A.; Neupane, S.; Chakraborty, T.; Mitra, S.; Mittal, S.; Pillai, N.; Chen, J.; Rahimi, S.: A survey on privacy attacks against digital twin systems in ai-robotics. In: 2024 IEEE 10th International Conference on Collaboration and Internet Computing (CIC), pp. 70–79. IEEE (2024)
40. Bäumer, F.S.; Schultenkämper, S.; Geierhos, M.; Lee, Y.S.: Mirroring privacy risks with digital twins: When pieces of personal data suddenly fit together. SN Comput. Sci. **5**(8), 1109 (2024)
41. Zhang, N., Bahsoon, R., Tziritas, N., Theodoropoulos, G.: A digital twin approach for adaptive compliance in cyber-physical systems: Case of smart warehouse logistics. arXiv preprint arXiv:2310.07116 (2023). https://doi.org/10.48550/arXiv.2310.07116
42. Garske, B.; Holz, W.; Ekardt, F.: Digital twins in sustainable transition: exploring the role of eu data governance. Front. Res. Metrics Anal. **9**, 1303024 (2024)
43. Molin, H.; Wärff, C.; Lindblom, E.; Arnell, M.; Carlsson, B.; Mattsson, P.; Bäckman, J.; Jeppsson, U.: Automated data transfer

for digital twin applications: Two case studies. Water Environ. Res. **96**(7), 11074 (2024)
44. Dhinakaran, D.; Kumar, N.J.; Ponnuviji, N., et al.: Safeguarding confidentiality and privacy in cloud-enabled healthcare systems with spectrasafe encryption and dynamic k-anonymity algorithm. Expert Syst. Appl. **279**, 127584 (2025)
45. Dhinakaran, D.; Prabaharan, G.; Valarmathi, K.; Sankar, S.U.; Sugumar, R.: Safeguarding privacy by utilizing sc-dlda algorithm in cloud-enabled multi party computation. KSII Trans. Int. Inf. Syst. **19**(2), 635–656 (2025)
46. Fuchs, D.; Bartz, R.; Kuschmitz, S.; Vietor, T.: Necessary advances in computer-aided design to leverage on additive manufacturing design freedom. Int. J. Int. Des. Manuf. **16**(4), 1633–1651 (2022)
47. Onaji, I.; Tiwari, D.; Soulatiantork, P.; Song, B.; Tiwari, A.: Digital twin in manufacturing: conceptual framework and case studies. Int. J. Comput. Integr. Manuf. **35**(8), 831–858 (2022)
48. Liao, Q.V., Gruen, D., Miller, S.: Questioning the AI: Informing design practices for explainable AI user experiences. In: Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems, pp. 1–15 (2020). https://doi.org/10.1145/3313831.3376590
49. Kobayashi, K., Almutairi, B., Sakib, M.N., Chakraborty, S., Alam, S.B.: Explainable, interpretable & trustworthy ai for intelligent digital twin: Case study on remaining useful life. arXiv preprint arXiv:2301.06676 (2023)
50. Mohammadi, B., Malik, N., Derdenger, T., Srinivasan, K.: Regulating explainable artificial intelligence (XAI) may harm consumers. Mark. Sci. **44**(3), 711–724 (2025). https://doi.org/10.1287/mksc.2022.0396
51. Sovrano, F., Lognoul, M., Vilone, G.: Aligning XAI with EU regulations for smart biomedical devices: Amethodology for compliance analysis. In: Endriss, U., Melo, F.S., Bach, K., Bugarin-Diz, A., Alonso-Moral, J.M., Barro, S., Heintz, F. (eds.) Proceedings of the 27th European Conference on Artificial Intelligence (ECAI 2024). Frontiers in Artificial Intelligence and Applications, vol. 392, pp. 826–833. IOS Press, Amsterdam (2024). https://doi.org/10.3233/FAIA240568
52. Grieman, K.; Early, J.: A risk-based approach to ai regulation: System categorisation and explainable ai practices. SCRIPTed **20**, 56 (2023)
53. Ebers, M.: Regulating explainable ai in the european union. an overview of the current legal framework (s). An Overview of the Current Legal Framework (s)(August 9, 2021). Liane Colonna/Stanley Greenstein (eds.), Nordic Yearbook of Law and Informatics (2020)
54. Alberto, N.: XAI and sustainability: Unifying regulatory standards and solutions for the future of environmental management. EarthArXiv (2024). https://doi.org/10.31223/X57Q63
55. Kuźniacki, B.; Almada, M.; Tyliński, K.; Górski, Ł; Winogradska, B.; Zeldenrust, R.: Towards explainable artificial intelligence (xai) in tax law: the need for a minimum legal standard. World Ttax J **14**, 573–616 (2022)
56. Pavlidis, G.: Unlocking the black box: analysing the eu artificial intelligence act's framework for explainability in ai. Law Innov. Technol. **16**(1), 293–308 (2024)
57. Perisic, A.; Perisic, B.: Digital twins verification and validation approach through the quintuple helix conceptual framework. Electronics **13**(16), 3303 (2024)
58. Chhetri, T.R.; Kurteva, A.; DeLong, R.J.; Hilscher, R.; Korte, K.; Fensel, A.: Data protection by design tool for automated gdpr compliance verification based on semantically modeled informed consent. Sensors **22**(7), 2763 (2022)
59. Parliament, E.: European Data Protection Directive (EU DPD). https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=celex%3A31995L0046
60. Paja, E., Dalpiaz, F., Giorgini, P. (2014). STS-Tool: Security Requirements Engineering for Socio-Technical Systems.In: Heisel, M., Joosen, W., Lopez, J., Martinelli, F. (eds) Engineering Secure Future Internet Services and Systems.Lecture Notes in Computer Science, vol 8431. Springer, Cham. https://doi.org/10.1007/978-3-319-07452-8_3
61. Rhahla, M.; Allegue, S.; Abdellatif, T.: A framework for gdpr compliance in big data systems. In: International Conference on Risks and Security of Internet and Systems, pp. 211–226. Springer (2019)
62. Rao, T.R.; Mitra, P.; Bhatt, R.; Goswami, A.: The big data system, components, tools, and technologies: a survey. Knowl. Inf. Syst. **60**, 1165–1245 (2019)
63. Amaral, O.; Abualhaija, S.; Briand, L.: Ml-based compliance verification of data processing agreements against gdpr. In: 2023 IEEE 31st International Requirements Engineering Conference (RE), pp. 53–64. IEEE (2023)
64. Barati, M.; Aujla, G.S.; Llanos, J.T.; Duodu, K.A.; Rana, O.F.; Carr, M.; Ranjan, R.: Privacy-aware cloud auditing for gdpr compliance verification in online healthcare. IEEE Trans. Industr. Inf. **18**(7), 4808–4819 (2021)
65. Andres-Jimenez, J.; Medina-Merodio, J.-A.; Fernandez-Sanz, L.; Martinez-Herraiz, J.-J.; Ruiz-Pardo, E.: An intelligent framework for the evaluation of compliance with the requirements of iso 9001: 2015. Sustainability **12**(13), 5471 (2020)
66. Laitenberger, O.; DeBaud, J.-M.: An encompassing life cycle centric survey of software inspection. J. Syst. Softw. **50**(1), 5–31 (2000)
67. Bahig, G.; El-Kadi, A.: Formal verification of automotive design in compliance with iso 26262 design verification guidelines. IEEE Access **5**, 4505–4516 (2017)
68. Bini, F.; Franzò, M.; Maccaro, A.; Piaggio, D.; Pecchia, L.; Marinozzi, F.: Is medical device regulatory compliance growing as fast as extended reality to avoid misunderstandings in the future? **13**(5), 831–842 https://doi.org/10.1007/s12553-023-00775-x . Accessed 2025-02-09
69. Safety and Privacy in Immersive Extended Reality: An Analysis and Policy Recommendations - Consensus. https://consensus.app/papers/safety-and-privacy-in-immersive-extended-reality-an-hine-rezende/bf6e760954005d3d8fcbc66e04b42067/?utm_source=chatgpt Accessed 2025-02-16
70. Giaretta, A.: Security and Privacy in Virtual Reality: A Literature Survey **29**(1), 10 https://doi.org/10.1007/s10055-024-01079-9 arXiv:2205.00208
71. Kim, Y.: Virtual Reality Data and Its Privacy Regulatory Challenges: A Call to Move Beyond Text-Based Informed Consent https://doi.org/10.15779/Z380Z70X6P . Accessed 2025-02-16
72. Henriksson, E.A.: Data protection challenges for virtual reality applications **1**(1), 57-61 https://doi.org/10.4337/ielr.2018.01.05 . Accessed 2025-02-16
73. Ryan, P.J.: Privacy and Inclusivity. In: 2018 IEEE Games, Entertainment, Media Conference (GEM), pp. 1–9. IEEE. https://doi.org/10.1109/GEM.2018.8516269. https://ieeexplore.ieee.org/document/8516269/ Accessed 2025-02-17
74. King, A.; Kaleem, F.; Rabieh, K.: A Survey on Privacy Issues of Augmented Reality Applications. In: 2020 IEEE Conference on Application, Information and Network Security (AINS), pp. 32-40. IEEE. https://doi.org/10.1109/AINS50155.2020.9315127. https://ieeexplore.ieee.org/document/9315127/ Accessed 2025-02-17
75. Kotsios, A.: Privacy in an augmented reality **23**(2), 157-185 https://doi.org/10.1093/ijlit/eav003 . Accessed 2025-02-17
76. LUBUA, E.; Pretorius, P.: Cyber-security policy framework and procedural compliance in public organisations. 3rd European International Conference on Industrial Engineering and Operations Management (2019)

77. Zemskov, A.D.; Fu, Y.; Li, R.; Wang, X.; Karkaria, V.; Tsai, Y..-K.; Chen, W.; Zhang, J.; Gao, R.; Cao, J.: Security and privacy of digital twins for advanced manufacturing: A survey, (2024).
78. Voas, J.; Mell, P.; Laplante, P.; Piroumian, V.: Security and Trust Considerations for Digital Twin Technology. Technical report, National Institute of Standards and Technology (2025)
79. O'Reilly, P.; Rigopoulos, K.: Fiscal Year 2024 Annual Report for NIST Cybersecurity and Privacy Program. Special Publication (NIST SP), National Institute of Standards and Technology, Gaithersburg, MD (2025). https://doi.org/10.6028/NIST.SP.800-236 . https://tsapps.nist.gov/publication/get_pdf.cfm?pub_id=959828
80. Technical report
81. Force, J.T.: Risk management framework for information systems and organizations. NIST Spec. Publ. **800**, 37 (2018)
82. ISO/IEC: Information security, cybersecurity and privacy protection - Information security management systems - Requirements. International Standard ISO/IEC 27001:2022 (2022)
83. ISO/IEC: Information security, cybersecurity and privacy protection - Guidelines for information security risk management. International Standard ISO/IEC 27005:2022 (2022)
84. ISO/IEC: ISO/IEC 29100:2024 Information technology - Security techniques - Privacy framework. International Standard ISO/IEC 29100:2024(en) (2024)
85. Information security, cybersecurity and privacy protection - Guidelines for protection of personally identifiable information (PII) in public clouds acting as PII processors. International Standard ISO/IEC **27018**, 2025 (2025) (**ISO/IEC: ISO/IEC 27018:2025**)
86. Security techniques - Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management - Requirements and guidelines. International Standard ISO/IEC **27701**, 2025 (2025) (**ISO/IEC: ISO/IEC 27701:2025**)
87. Force, J.T.: Assessing security and privacy controls in information systems and organizations. NIST Spec. Publ. **800**, 53 (2022)
88. ISO/IEC: Information security, cybersecurity and privacy protection - Information security controls. International Standard ISO/IEC 27002:2022 (2022)
89. Gruschka, N.; Mavroeidis, V.; Vishi, K.; Jensen, M.: Privacy issues and data protection in big data: a case study analysis under gdpr. In: 2018 IEEE International Conference on Big Data (Big Data), pp. 5027–5033. IEEE (2018)
90. Bastos, D.; Giubilo, F.; Shackleton, M.; El-Moussa, F.: Gdpr privacy implications for the internet of things. In: 4th Annual IoT Security Foundation Conference, Vol. 4, pp. 1–8. (2018)
91. Bernabe, J.B.; Canovas, J.L.; Hernandez-Ramos, J.L.; Moreno, R.T.; Skarmeta, A.: Privacy-preserving solutions for blockchain: Review and challenges. Ieee Access **7**, 164908–164940 (2019)
92. Haque, A.B.; Islam, A.N.; Hyrynsalmi, S.; Naqvi, B.; Smolander, K.: Gdpr compliant blockchains-a systematic literature review. Ieee Access **9**, 50593–50606 (2021)
93. Wouters, B.; Shaw, D.; Sun, C.; Ippel, L.; Soest, J.; Berg, B.; Mussmann, O.; Koster, A.; Kallen, C.; Oppen, C., et al.: Putting the gdpr into practice: difficulties and uncertainties experienced in the conduct of big data health research. Eur. Data Prot. L. Rev. **7**, 206 (2021)
94. Almeida, F.; Monteiro, J.A.: Exploring the effects of gdpr on the user experience. J. Inf. Syst. Eng. Manag. **6**(3), 1–40 (2021)
95. Stouffer, K., Pease, M., Tang, C., Zimmerman, T., Pillitteri, V., Lightman, S., Hahn, A., Saravia, S., Sherule, A., Thompson, M.: Guide to Operational Technology (OT) Security. NIST Special Publication (SP) 800-82 Revision 3, National Institute of Standards and Technology, Gaithersburg, MD (2023). https://doi.org/10.6028/NIST.SP.800-82r3
96. Ross, R.; Pillitteri, V.; Dempsey, K.: Assessing enhanced security requirements for controlled unclassified information. NIST Spec. Publ. **800**, 172 (2022)
97. McKay, K.; Cooper, D.: Guidelines for the Selection, Configuration, and Use of Transport Layer Security (tls) Implementations. Technical report, National Institute of Standards and Technology (2017)
98. McCallister, E.; Grance, T.; Scarfone, K.: Identifiable information (pii). NIST Spec. Publ. **800**(122), 3 (2010)
99. Rose, S.; Borchert, O.; Mitchell, S.; Connelly, S.: Nist special publication 800-207 zero trust architecture. NIST National Institute of Standards and Technology US Department of Commerce, 800-207 (2020)
100. Grassi, P.A., Newton, E.M., Perlner, R.A., Regenscheid, A.R., Burr, W.E., Richer, J.P., Lefkovitz, N.B., Danker, J.M.,Choong, Y.-Y., Greene, K., Theofanos, M.F.: Digital Identity Guidelines: Authentication and Lifecycle Management. NIST Special Publication (SP) 800-63B, National Institute of Standards and Technology, Gaithersburg, MD (2017). https://doi.org/10.6028/NIST.SP.800-63B
101. ISO/IEC: Information security, cybersecurity and privacy protection - Information security incident management. International Standard ISO/IEC 27035:2023 (2023)
102. ISO/IEC: ISO/IEC 27004:2016 Inform Information technology - Security techniques - Information security management - Monitoring, measurement, analysis and evaluation. International Standard ISO/IEC 27004:2016(en) (2016)
103. Jain, V., Balakrishnan, A., Beeram, D., Najana, M., Chintale, P.: Leveraging artificial intelligence for enhancingregulatory compliance in the financial sector. Int. J. Comput. Trends Tech. **72**(5), 124–140 (2024). https://doi.org/10.14445/22312803/IJCTT-V72I5P116
104. Moharrak, M.; Mogaji, E.: Generative ai in banking: empirical insights on integration, challenges and opportunities in a regulated industry. Int. J. Bank Market. **43**(4), 871–896 (2025)
105. Muhlheim, M.D., Ramuhalli, P., Huning, A., Guler Yigitoglu, A., Wood, R.T., Saxena, A.: Status Report on Regulatory Criteria Applicable to the Use of Digital Twins. ORNL/SPR-2022/2493, Oak Ridge National Laboratory, OakRidge, TN (2022). https://doi.org/10.2172/1883838
106. Freeman, E.H.: Regulatory compliance and the chief compliance officer. Inf. Syst. Secur. **16**(6), 357–361 (2007)
107. Damjanovic-Behrendt, V.: A digital twin-based privacy enhancement mechanism for the automotive industry. In: 2018 International Conference on Intelligent Systems (IS), pp. 272–279. IEEE (2018)
108. Alex-Omiogbemi, A.A., Sule, A.K., Omowole, B.M., Owoade, S.J.: Conceptual framework for advancing regulatory compliance and risk management in emerging markets through digital innovation. World J. Adv. Res. Rev. **24**(3), 1155–1162 (2024). https://doi.org/10.30574/wjarr.2024.24.3.3752
109. Butler, T., & O'Brien, L. (2019). Understanding RegTech for digital regulatory compliance. In Disrupting Finance(Vol. 1, pp. 85–102). Springer Nature. https://doi.org/10.1007/978-3-030-02330-0_6
110. Tilala, M.; Chawda, A.D.; Benke, A.P.: Enhancing regulatory compliance through training and development programs: Case studies and recommendations. J. Cardiovasc. Res **14**, 1839–1850 (2023)
111. Trinity, G.H.; Sharma, N.: Cybersecurity regulations and compliance: Balancing privacy and protection in the digital age. In: 2023 Seventh International Conference on Image Information Processing (ICIIP), pp. 794–799. IEEE (2023)
112. Hu, S.; Hsu, C.; Zhou, Z.: Security education, training, and awareness programs: Literature review. J. Comput. Inf. Syst. **62**(4), 752–764 (2022)

113. Abu-Amara, F.; Almansoori, R.; Alharbi, S.; Alharbi, M.; Alshehhi, A.: A novel seta-based gamification framework to raise cybersecurity awareness. Int. J. Inf. Technol. **13**(6), 2371–2380 (2021)
114. Kirova, D.; Bauml, U.: Factors that affect the success of security education, training, and awareness programs: A literature review. J. Inf. Technol. Theory Appl. **19**(4), 4 (2018)

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.